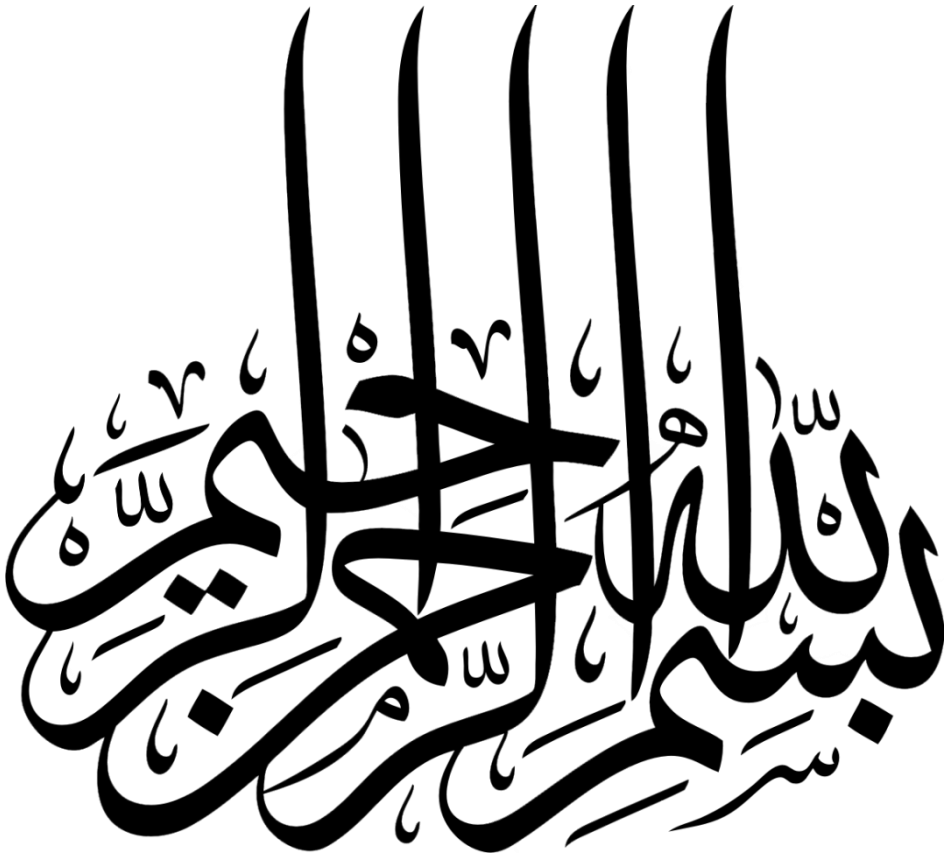

بسم الله الرحمن الرحيم

گزارش تست نفوذپذیری

سامانه fanava.com

مشخصات سند:

کارفرما	پیمانکار	تاریخ نگارش سند
گروه فناوا	دهکده امن فناورانه صبا	۲ خرداد ماه ۱۴۰۵

تهیه شده توسط	شماره مستند	طبقه بندی
مدیریت فنی و ارزیابی	TARA-PRO-1405-0302-017	محرمانه

مشخصات شرکت:

آدرس	شماره تماس
تهران – خیابان انقلاب اسلامی – خیابان استاد نجات الهی	۰۲۱-۸۸۹۳۵۹۲۰
کوچه سلمان پاک – پلاک ۱۶ واحد ۴	۰۲۱-۲۸۴۲۶۰۷۸

تمام مطالب مندرج در این سند متعلق به شرکت دهکده امن فناورانه صبا و استفاده از آن منوط به مجوز کتبی از شرکت می‌باشد.



فهرست مطالب

عنوان **صفحه**

مقدمه و خلاصه نتایج ۴

متدولوژی آزمون نفوذ ۵

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون ۷

محیط ارزیابی ۷

شناسایی وب‌سرور ۷

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه ۷

خلاصه مدیریتی ۹

تشریح آسیب‌پذیری‌های کشف شده ۱۲

آسیب‌پذیری عبور از مکانیزم کپچا تعریف شده در سامانه ۱۲

آسیب‌پذیری بارگذاری فایل با محتوی مخرب ۱۳

حمله Reverse Denial of Service ۱۳

آسیب‌پذیری در دسترس بودن صفحه XML RPC ۱۳

آسیب‌پذیری Session Fixation ۱۳

آسیب‌پذیری عدم مدیریت خطاهای پیش‌فرض ۱۳

آسیب‌پذیری HTTP Splitting Smuggling ۱۳

آسیب‌پذیری CVE-2026-4406 - Reflected XSS ۱۳

آسیب‌پذیری Directory Listing ۱۳

آسیب‌پذیری اعتبارسنجی ورودی‌ها ۱۳

آسیب‌پذیری Click-Jacking ۱۳

عدم وجود سرآیندهای امنیتی HTTP ۱۳

مقدمه و خلاصه نتایج

در دنیای امروز، که هر شرکت یا سازمانی دارایی‌های مختلف حوزه فناوری اطلاعات را در خود جای داده است، امنیت این دارایی‌ها نیز در جایگاه مهمی قرار می‌گیرد. با گسترش روزافزون تهدیدات سایبری و پیچیده‌تر شدن شیوه‌های نفوذ، تکیه بر ابزارهای دفاعی سنتی به تنهایی کافی نیست؛ از این رو، ارزیابی مستمر و شناسایی فعالانه نقاط ضعف پیش از بهره‌برداری توسط مهاجمان، به یکی از ارکان اصلی استمرار کسب‌وکار تبدیل شده است.

در اکوسیستم دیجیتالِ امروز، دارایی‌های فناوری اطلاعات نه تنها زیرساخت تداوم خدمات، بلکه قلب تپنده و حافظ سرمایه‌های استراتژیک سازمان هستند. با این حال، امنیت در فضای سایبری حالتی ایستا ندارد؛ بلکه تابعی است از تکامل مداوم تکنولوژی و هوشمندی تهدیداتی که هر روز پیچیده‌تر و هدفمندتر می‌شوند.

تکیه بر تنظیمات پیش‌فرض یا ابزارهای امنیتی معمول، اگرچه لایه‌ای از حفاظت را ایجاد می‌کند، اما به معنای مصونیت مطلق نیست؛ چرا که نفوذگران همواره به دنبال شناسایی شکاف‌هایی هستند که از دید سیستم‌های نظارتی دور مانده یا به دلیل خطاهای پیکربندی انسانی نادیده گرفته شده‌اند.

ارزیابی امنیتی و تست نفوذ که در این گزارش ارائه شده است، فراتر از یک بررسی سطحی، تلاشی است برای مشاهده‌ی سازمان از دریچه‌ی نگاه مهاجم. هدف ما در این ارزیابی، شناسایی نقاط کور و کشف مسیرهایی است که می‌تواند منجر به دسترسی‌های غیرمجاز یا نشت اطلاعات حساس گردد.

این گزارش حاصل تست نفوذ انجام شده بر روی **وب سایت fanava.com** است که با هدف ارزیابی جامع امنیت دارایی‌های دیجیتال **گروه فناوا** تهیه شده است. هدف از این ارزیابی، شناسایی آسیب‌پذیری‌های امنیتی، تحلیل پیامدهای احتمالی و ارائه راهکارهای عملیاتی جهت کاهش ریسک و ارتقای سطح بلوغ امنیتی زیرساخت‌ها بوده است.

متدولوژی آزمون نفوذ

به منظور حصول اطمینان از دقت، جامعیت و قابلیت بازتولید یافته‌ها، فرآیند ارزیابی امنیتی در این پروژه بر اساس استاندارد جهانی WSTG (Web Security Testing Guide) تدوین‌شده توسط بنیاد امنیتی OWASP در ترکیب با تجربه عملی متخصصان شرکت صورت گرفته است. این چارچوب مرجع، به عنوان استاندارد صنعتی برای تست نفوذ برنامه‌های کاربردی تحت وب، لایه‌های مختلف امنیتی از پیکربندی سرور و مدیریت نشست‌ها گرفته تا کنترل‌های احراز هویت و دسترسی را تحت پوشش قرار می‌دهد.

در اجرای این متدولوژی، مراحل زیر به صورت گام‌به‌گام پیاده‌سازی شده است:

- **فاز شناسایی و جمع‌آوری اطلاعات:** تحلیل ساختار برنامه، شناسایی تکنولوژی‌های مورد استفاده، نقشه‌برداری از سطوح حمله و کشف فایل‌ها و دایرکتوری‌های حساس.
- **فاز تحلیل پیکربندی و کنترل‌های امنیتی:** بررسی تنظیمات امنیتی وب‌سرور، نحوه مدیریت نشست‌ها، مکانیزم‌های احراز هویت و مجوزدهی، و تحلیل نحوه برخورد سیستم با داده‌های ورودی کاربر.
- **فاز شناسایی آسیب‌پذیری‌ها:** اجرای تست‌های هدفمند برای کشف نقاط ضعف در لایه‌های مختلف از جمله تزریق کد، XSS، کنترل‌های دسترسی ناامن و سایر ریسک‌های شناخته شده در استاندارد WSTG.
- **فاز بهره‌برداری و تأیید آسیب‌پذیری شناسایی شده:** تلاش کنترل‌شده برای بهره‌برداری از آسیب‌پذیری‌های شناسایی شده به منظور اثبات صحت آن‌ها و درک میزان اثرگذاری هر ریسک بر روی داده‌ها و عملکرد کلی سیستم.

پس از شناسایی و تأیید آسیب‌پذیری‌ها، جهت تحلیل دقیق و استاندارد سطح ریسک هر یافته، از سیستم امتیازدهی CVSS (Common Vulnerability Scoring System) استفاده شده است. این مدل با در نظر گرفتن فاکتورهای فنی نظیر بردار حمله، میزان پیچیدگی بهره‌برداری و تأثیر بر محرمانگی، یکپارچگی و دسترس‌پذیری اطلاعات، عددی را بین ۰ تا ۱۰ به هر آسیب‌پذیری اختصاص می‌دهد.

بهره‌گیری از CVSS به سازمان کمک می‌کند تا با زبانی مشترک و تخصصی، اهمیت یافته‌ها را درک کرده و فرآیند اصلاح را بر اساس اولویت‌بندی دقیق و منطقی مدیریت نماید. بدین ترتیب، آسیب‌پذیری‌هایی با امتیاز بالاتر، به عنوان اولویت‌های فوری برای تیم فنی جهت کاهش سطح حمله و ارتقای تاب‌آوری سیستم تعیین شده‌اند.

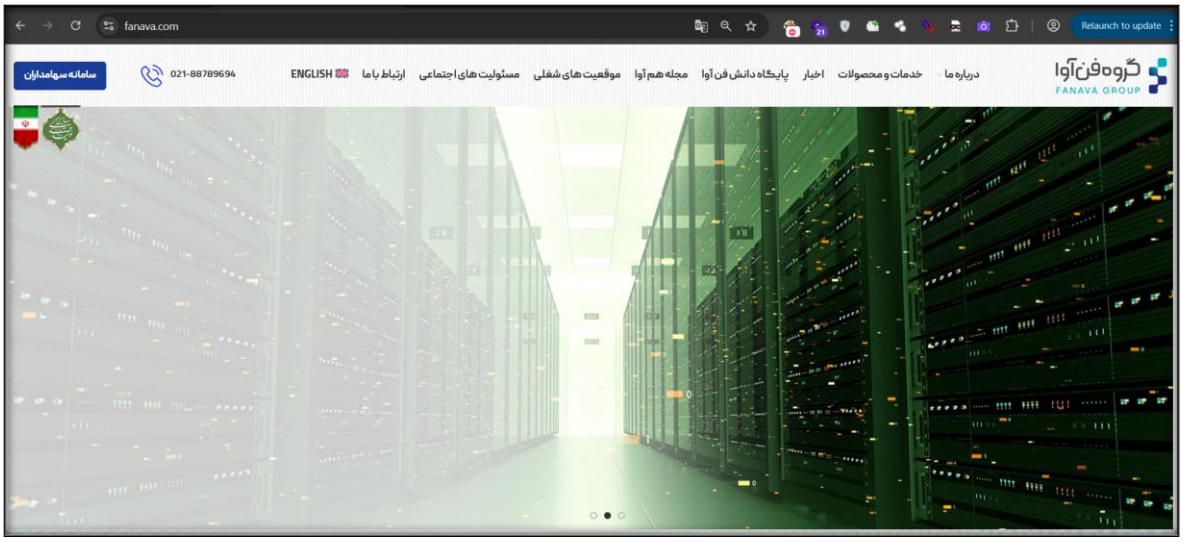
این رویکرد ساختاریافته به تیم ارزیاب اجازه می‌دهد تا فراتر از ابزارهای خودکار، با نگاهی تحلیلی به بررسی پیچیدگی‌های منطقی برنامه بپردازد و اطمینان حاصل کند که تمامی جنبه‌های حیاتی امنیتِ وب‌سایت در برابر تهدیدات پیشرفته مورد سنجش قرار گرفته‌اند.

اطلاعات کلی مرتبط با دارایی و محدوده مورد آزمون

محیط ارزیابی

در این بخش، نمایی از وب‌سایت هدف جهت مستندسازیِ وضعیت سیستم در زمان شروع ارزیابی ارائه شده است. این تصویر به عنوان مرجعی برای تایید دامنه فعالیت و شناسایی بصری رابط کاربریِ سیستمِ تحت تست می‌باشد.

سامانه هدف با آدرس https://fanava.com در حال سرویس‌دهی است که صفحه نخست آن در تصویر زیر نمایش داده شده است:



شناسایی وب‌سرور

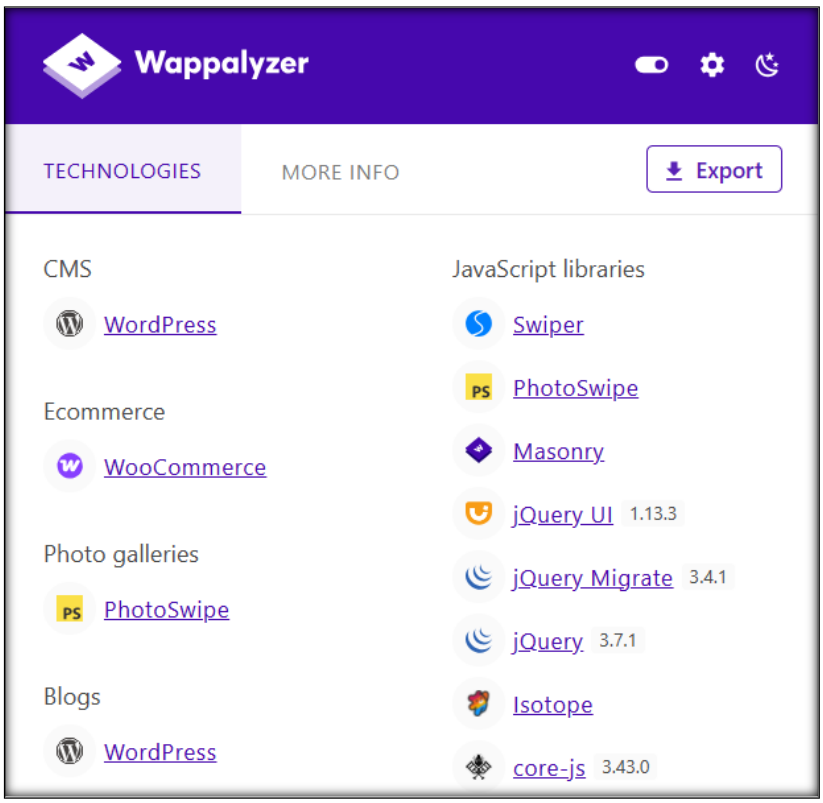
یکی از مراحل بنیادین در فاز شناسایی، تعیین دقیق نوع و نسخه وب‌سرور میزبان است. تحلیل دقیق پاسخ‌های HTTP (مانند هدرهای Server و X-Powered-By) و بررسی الگوهای رفتاری سرور، به ارزیاب اجازه می‌دهد تا زیرساخت میزبان را به دقت شناسایی کند.

داشتن این اطلاعات، امکان انطباق سیستم با پایگاه داده‌های آسیب‌پذیری‌های شناخته شده (CVEs) را فراهم می‌آورد. در واقع، هدف از این گام، ترسیم نقشه دقیق سطح حمله است تا از طریق استخراج اطلاعات فنی دقیق، بهره‌برداری‌های متناسب با پیکربندی خاص سرور در مراحل بعدی ارزیابی، به‌صورت هدفمند و مؤثر طراحی و اجرا گردد.

شناسایی فریم‌ورک‌ها و تکنولوژی‌های فعال روی سامانه

به منظور شناسایی دقیق زیرساخت و تکنولوژی‌های مورد استفاده در سامانه هدف، از ترکیب روش‌های تحلیل دستی و ابزارهای تحلیل خودکار استفاده شد. در این فرآیند، با بررسی دقیق هدرهای پاسخ HTTP،

ساختار کوکی‌ها، نام فیلدهای فرم، و همچنین استفاده از ابزارهای تخصصی انگشت‌نگاری نظیر Wappalyzer، اطلاعات فنی سامانه استخراج گردید. تصویر زیر مربوط به این موضوع می‌باشد:



خلاصه مدیریتی

ارزیابی امنیتی انجام‌شده بر روی سامانه fanava.com نشان می‌دهد که علی‌رغم لایه‌های حفاظتی موجود، چندین شکاف امنیتی با سطوح ریسک متفاوت در معماری و پیاده‌سازی سامانه وجود دارد. شناسایی و بهره‌برداری از این موارد می‌تواند منجر به بروز مخاطرات جدی از قبیل دسترسی غیرمجاز به اطلاعات کاربران، اختلال در دسترس‌پذیری سرویس و در نهایت آسیب به اعتبار سازمانی گردد.

تحلیل وضعیت موجود

یافته‌های این گزارش بر اساس سیستم امتیازدهی CVSS دسته‌بندی شده‌اند تا مدیران و تیم فنی بتوانند فرآیند مقاوم‌سازی را با اولویت‌بندی صحیح آغاز کنند:

- **ریسک‌های سطح زیاد:** این موارد شامل آسیب‌پذیری‌هایی است که اجازه دور زدن کنترل‌های امنیتی اصلی (مانند کپچا) یا اجرای حملات مخرب (مانند بارگذاری فایل‌های غیرمجاز و حملات DoS) را به مهاجم می‌دهد. رفع این موارد به دلیل پتانسیل بالای سوءاستفاده، اولویت نخست سازمان محسوب می‌شود.
- **ریسک‌های سطح متوسط:** این یافته‌ها به شکاف‌هایی در پیکربندی، مدیریت نشست‌ها و اعتبارسنجی ورودی‌ها اشاره دارد. اگرچه این موارد ممکن است به تنهایی منجر به نفوذ کامل نشوند، اما می‌توانند در زنجیره‌ای از حملات، راه را برای نفوذگر هموار سازند.
- **ریسک‌های سطح کم:** مربوط به عدم استفاده از برخی استانداردهای امنیتی HTTP است که اگرچه خطر مستقیم ایجاد نمی‌کنند، اما «لایه دفاعی» سامانه را ضعیف کرده و شناساییِ هدف را برای مهاجم آسان‌تر می‌کنند.

جمع بندی:

وضعیت امنیتی کنونی سامانه نیازمند توجه فوری تیم‌های توسعه و راهبری است. پیشنهاد می‌شود ابتدا آسیب‌پذیری‌های با **ریسک زیاد** بر اساس راهکارهای ارائه‌شده در این گزارش اصلاح شوند. پس از آن، پرداختن به ریسک‌های متوسط جهت افزایش تاب‌آوری سامانه در برابر حملات هدفمند توصیه می‌گردد. اجرای این اقدامات، نه تنها تهدیدات شناسایی‌شده را مرتفع می‌کند، بلکه سطح بلوغ امنیتی سازمان را در برابر تهدیدات سایبری نوظهور ارتقا خواهد داد.

همچنین لازم به ذکر است که آسیب‌پذیری‌های سطح ریسک متوسط و کم نباید نادیده گرفته شده و با توجه به تجمیع برخی از آن‌ها، امکان سوء استفاده از این سطح آسیب‌پذیری‌ها در صورت عدم رفع، وجود خواهد داشت.

خلاصه یافته‌های ارزیابی



در جدول زیر، تمامی آسیب‌پذیری‌های شناسایی‌شده در طول ارزیابی امنیتی، بر اساس شدت ریسک و طبق CVSS دسته‌بندی شده‌اند. این طبقه‌بندی به سازمان کمک می‌کند تا با نگاهی کلان، اولویت‌های اصلی امن‌سازی خود را شناسایی و منابع فنی را به بهینه‌ترین شکل برای رفع آن‌ها تخصیص دهد.

درجه اهمیت	توضیح آسیب‌پذیری
زیاد	عبور از مکانیزم کپچا تعریف شده در سامانه
زیاد	آسیب‌پذیری Fuction Limit Use
زیاد	آسیب‌پذیری بارگذاری فایل با محتوی مخرب
زیاد	حمله Reverse Denial of Service
متوسط	آسیب‌پذیری در دسترس بودن صفحه XML RPC
متوسط	آسیب‌پذیری Session Fixation
متوسط	عدم مدیریت خطاهای پیش فرض
متوسط	آسیب‌پذیری HTTP Splitting Smuggling
متوسط	آسیب‌پذیری CVE-2026-4406 - Reflected XSS
متوسط	آسیب‌پذیری Directory Listing
متوسط	آسیب‌پذیری اعتبارسنجی ورودی‌ها
متوسط	آسیب‌پذیری Click-Jacking
کم	عدم وجود سرآیندهای امنیتی HTTP

توصیه

شایان ذکر است آسیب‌پذیری‌های گزارش‌شده در بخش‌های آتی، به عنوان نمونه‌های شاخص از وضعیت امنیتی سامانه ارائه شده‌اند. از این رو، اکیداً توصیه می‌شود تیم فنی سازمان، راهکارهای اصلاحی ارائه‌شده را نه تنها برای نمونه‌های تست‌شده، بلکه به صورت جامع در تمامی بخش‌ها و ماژول‌های مشابه در کل سامانه اعمال نمایند تا از بروز شکاف‌های امنیتی مشابه در سایر نقاط سیستم جلوگیری شود.

تشریح آسیب‌پذیری‌های کشف شده

در ادامه، برای آسیب‌پذیری‌های کشف‌شده در سامانه، توضیحات تکمیلی مرتبط ارائه شده است:

آسیب‌پذیری عبور از مکانیزم کپچا تعریف شده در سامانه

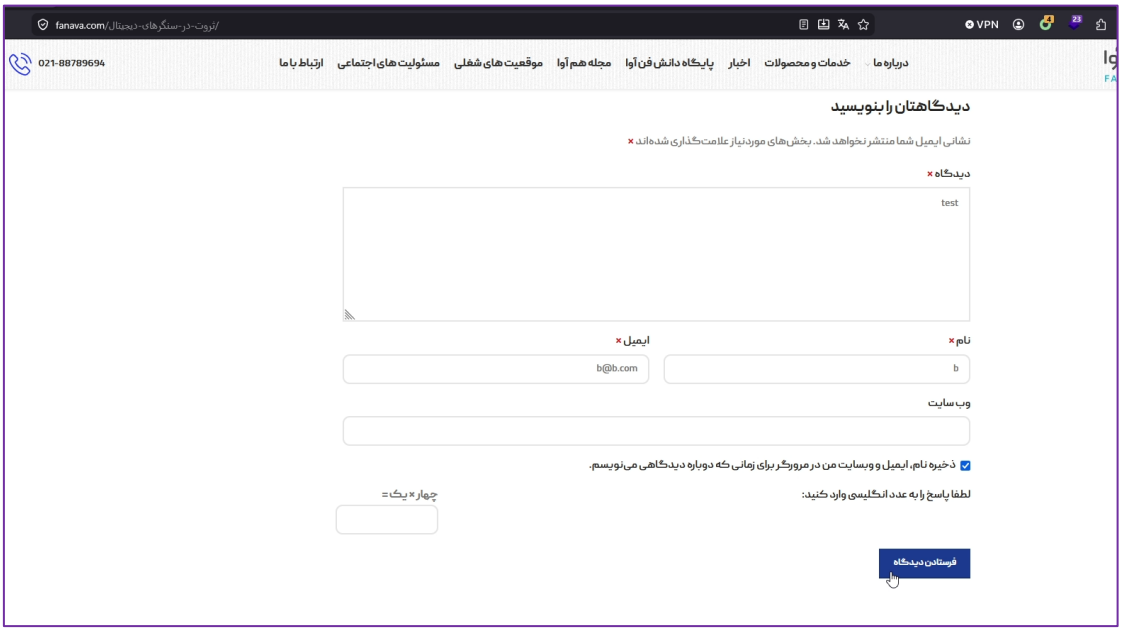
آسیب‌پذیری‌های مرتبط با جریان کار در منطق کسب و کار، هر نوعی از آسیب‌پذیری را که مهاجم امکان سوءاستفاده از برنامه یا سیستم را داشته باشد به نحوی که بتواند فرایند جریان کار فعالیت‌ها را دور بزند، (حذف یا جابجا و یا اضافه کند)، شامل می‌شود.

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش اضافه کردن دیدگاه بخش کپچا وجود دارد که کاربر باید مقدار صحیح آن را وارد کند تا بتواند دیدگاه خود را ثبت کند. مهاجم می‌تواند با یک مقدار گپچا چندین دیدگاه در سامانه ثبت کند و عملا این مکانیزم امنیتی را دور بزند.

شواهد اثبات آسیب پذیری

مستندات این آسیب‌پذیری به شرح زیر است.

تصویر زیر بخش اضافه کردن دیدگاه و بخش وارد کردن کپچا را نشان می‌دهد. به عنوان کپچا کاربر باید حاصل ۴*۱ را وارد کند:

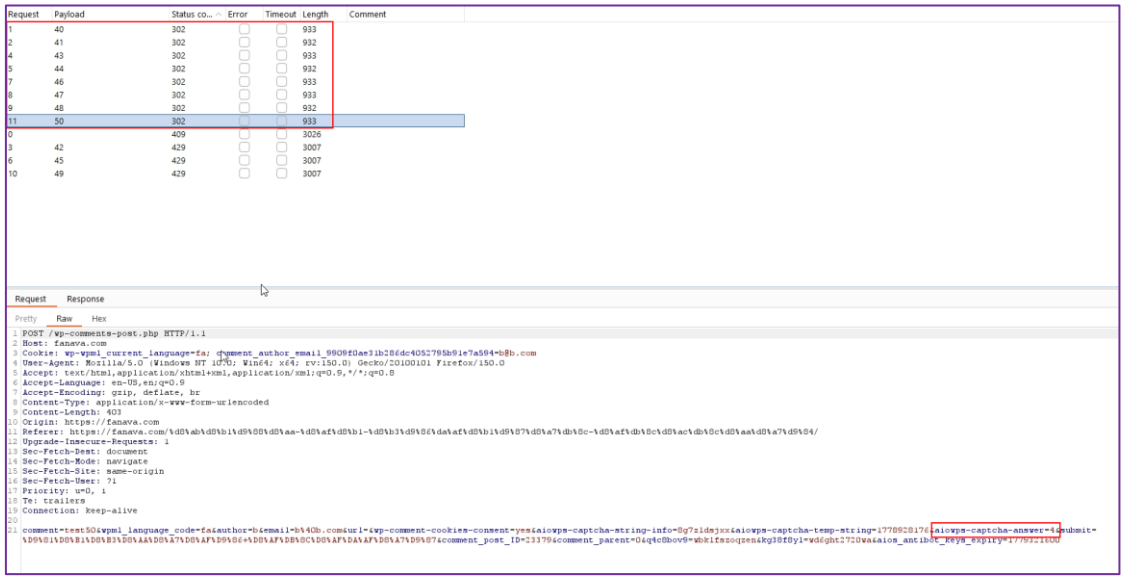


درخواست ارسال دیدگاه در تصویر زیر نمایش داده شده است:

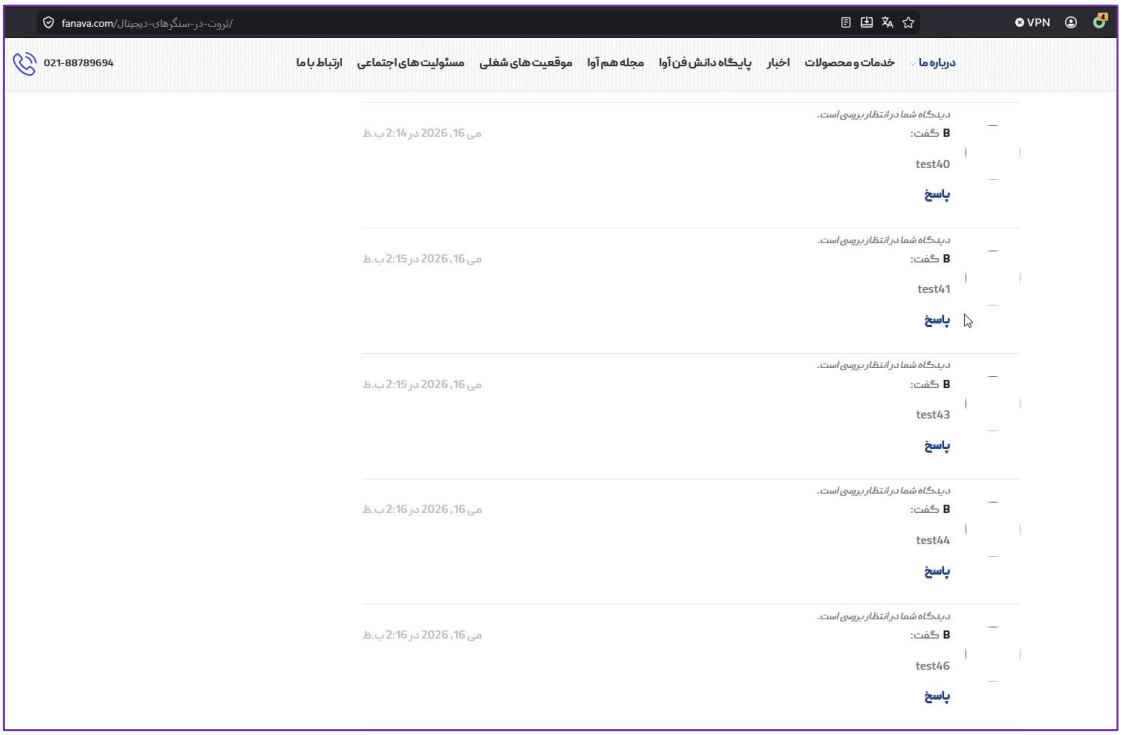


در تصویر زیر کاربر چندین درخواست ثبت دیدگاه با متن test و قرار دادن شماره‌های ۴۰ تا ۵۰ در متن کامنت (برای بهتر مشخص شدن نتیجه حمله) را با یک مقدار کپچا به سمت سامانه ارسال می‌کند. این درخواست‌ها با بازه زمانی ۱ ثانیه در بین هر درخواست به سمت سامانه ارسال شده است.

همان‌طور که در تصویر زیر قابل مشاهده می‌باشد از بین ۱۲ درخواست ۸ درخواست با موفقیت به سمت سامانه ارسال شده است و مابقی درخواست‌ها با خطا مواجه شده‌اند:



همان‌طور که در تصویر زیر قابل مشاهده است تمامی درخواست‌های موفق تصویر بالا در سامانه ثبت شده‌اند:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا مکانیزم کپچای سامانه به درستی پیاده سازی شود تا کاربر امکان ثبت دیدگاه بدون در اختیار داشتن کپچا و یا با کپچای تکراری را نداشته باشد.

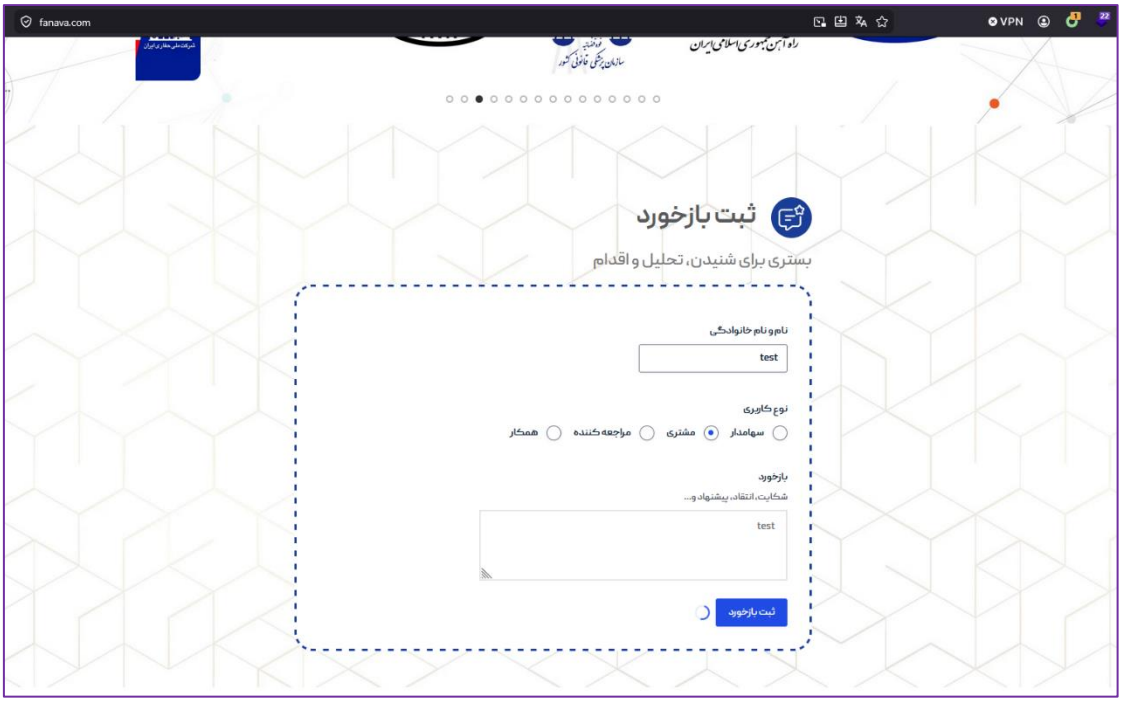
آسیب‌پذیری Fuction Limit Use

آسیب‌پذیری‌های مرتبط با جریان کار در منطق کسب و کار، هر نوعی از آسیب‌پذیری را که مهاجم امکان سوءاستفاده از برنامه یا سیستم را داشته باشد به نحوی که بتواند فرایند جریان کار فعالیت‌ها را دور بزند، (حذف یا جابجا و یا اضافه کند)، شامل می‌شود. یکی از مشکلاتی که بسیاری از وب سایت‌ها با آن مواجه هستند عدم ایجاد محدودیت در تعداد دفعات اجرای یک فعالیت و یا استفاده بیش از یک بار از یک تابع می‌باشد

با توجه به بررسی‌های انجام شده در سامانه، در هنگام ثبت بازخورد در صفحه اصلی سامانه هیچ مکانیزمی برای جلوگیری از ارسال درخواست‌های متوالی وجود ندارد و مهاجم می‌تواند بی‌نهایت بار درخواست ثبت بازخورد را در سامانه ثبت کند.

شواهد اثبات آسیب پذیری

در تصویر زیر بخش ثبت بازخورد نمایش داده شده است:

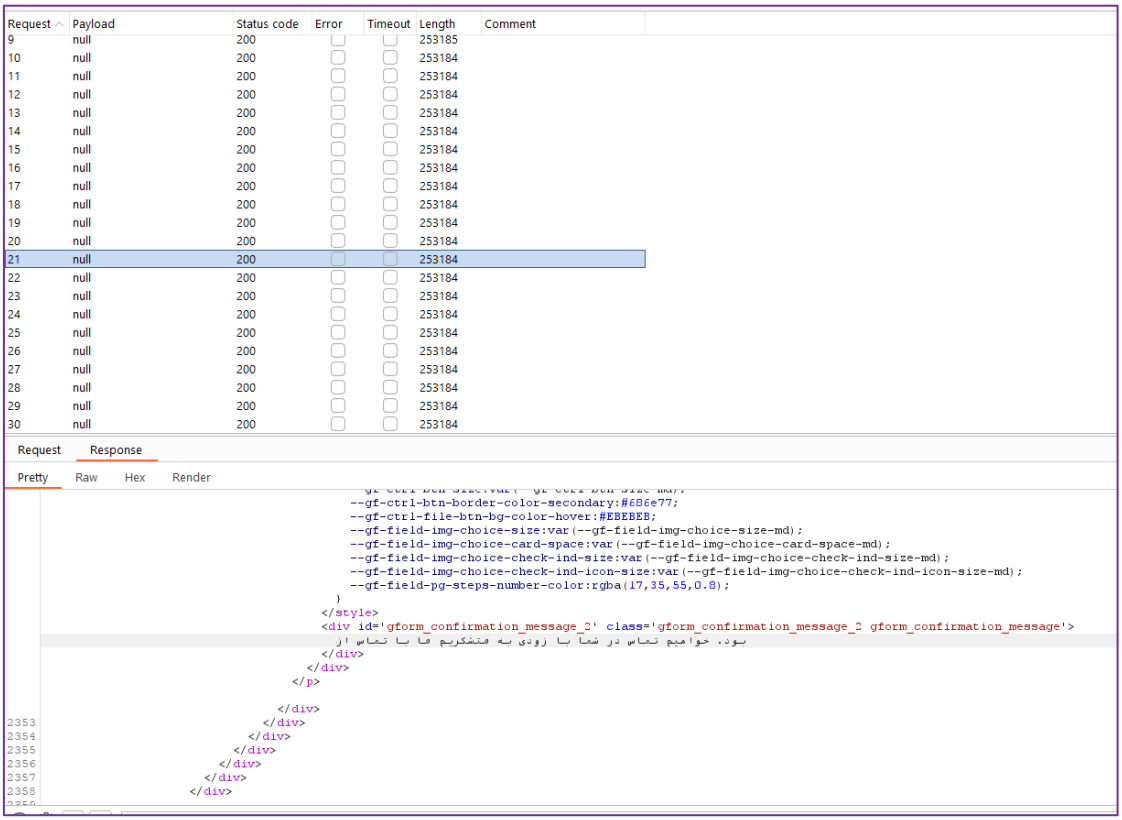


درخواست ثبت بازخورد در تصویر زیر نمایش داده شده است:

Pretty Raw Hex

```
1 POST / HTTP/1.1
2 Host: fanava.com
3 Cookie: wp-wpml_current_language=fa
4 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.9
7 Accept-Encoding: gzip, deflate, br
8 Content-Type: multipart/form-data; boundary=----geckoformboundary33d599ff99a85813668968 8c4631f67e
9 Content-Length: 2024
10 Origin: https://fanava.com
11 Referer: https://fanava.com/
12 Upgrade-Insecure-Requests: 1
13 Sec-Fetch-Dest: document
14 Sec-Fetch-Mode: navigate
15 Sec-Fetch-Site: same-origin
16 Sec-Fetch-User: ?1
17 Priority: u=0, i
18 Te: trailers
19 Connection: close
20
21 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
22 Content-Disposition: form-data; name="input_1"
23
24 test
25 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
26 Content-Disposition: form-data; name="input_3"
27
28 مشتری
29 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
30 Content-Disposition: form-data; name="input_4"
31
32 test
33 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
34 Content-Disposition: form-data; name="gform_submission_method"
35
36 postback
37 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
38 Content-Disposition: form-data; name="gform_theme"
39
40 orbital
41 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
42 Content-Disposition: form-data; name="gform_style_settings"
43
44 []
45 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
46 Content-Disposition: form-data; name="is_submit_2"
47
48 1
49 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
50 Content-Disposition: form-data; name="gform_submit"
51
52 2
53 ------geckoformboundary33d599ff99a85813668968 8c4631f67e
54 Content-Disposition: form-data; name="gform_unique_id"
```

در تصویر زیر مهاجم این درخواست را به صورت متوالی به سمت سامانه ارسال می‌کند. همان‌طور که در این تصویر قابل مشاهده می‌باشد تمامی درخواست‌ها با موفقیت در سامانه ثبت شده‌اند و پیغام مربوط به آن در صفحه نمایش داده شده است:



نکته: این آسیب‌پذیری می‌تواند در سایر بخش‌های سامانه مانند ثبت فرم همکاری که امکان ارسال درخواست‌های متوالی بدون جلوگیری مهاجم را دارد، وجود داشته باشد.

راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا از ارسال درخواست‌های متوالی به سمت سامانه جلوگیری شود تا امکان ثبت درخواست ثبت بازخورد به صورت بینهایت برای مهاجم وجود نداشته باشد. در این بخش می‌توان از مکانیزم‌های امنیتی مانند کپچا برای جلوگیری از ارسال این درخواست‌ها استفاده کرد.

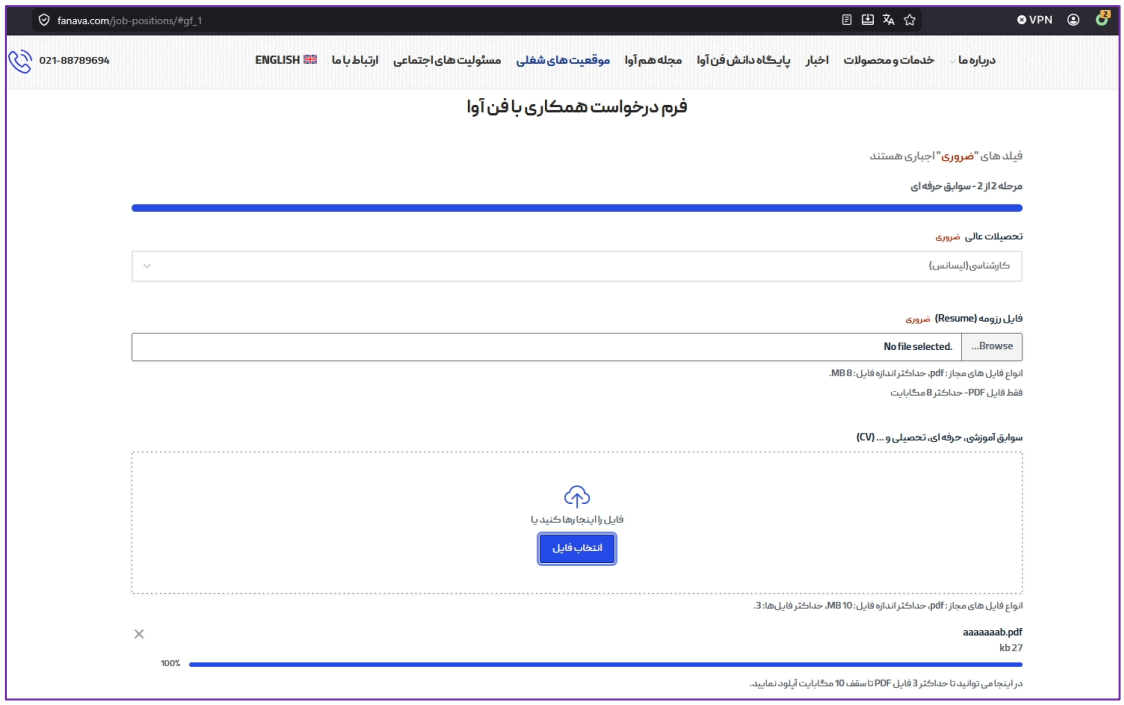
آسیب‌پذیری بارگذاری فایل با محتوی مخرب

مهاجم می‌تواند با بارگذاری فایل مخرب در سامانه منجر به آلوده شدن سرور و یا در شرایطی خطرناک‌تر ایجاد یک backdoor در سمت سرور شود.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش فرم درخواست همکاری هیچ مکانیزمی برای بررسی محتوی فایل ارسالی به سمت سرور وجود ندارد و مهاجم می‌تواند اقدام به بارگذاری فایل با محتوی مخرب کند.

تصویر زیر بخش فرم درخواست همکاری را نشان می‌دهد. در این بخش امکان بارگذاری فایل رزومه و سوابق آموزشی وجود دارد:



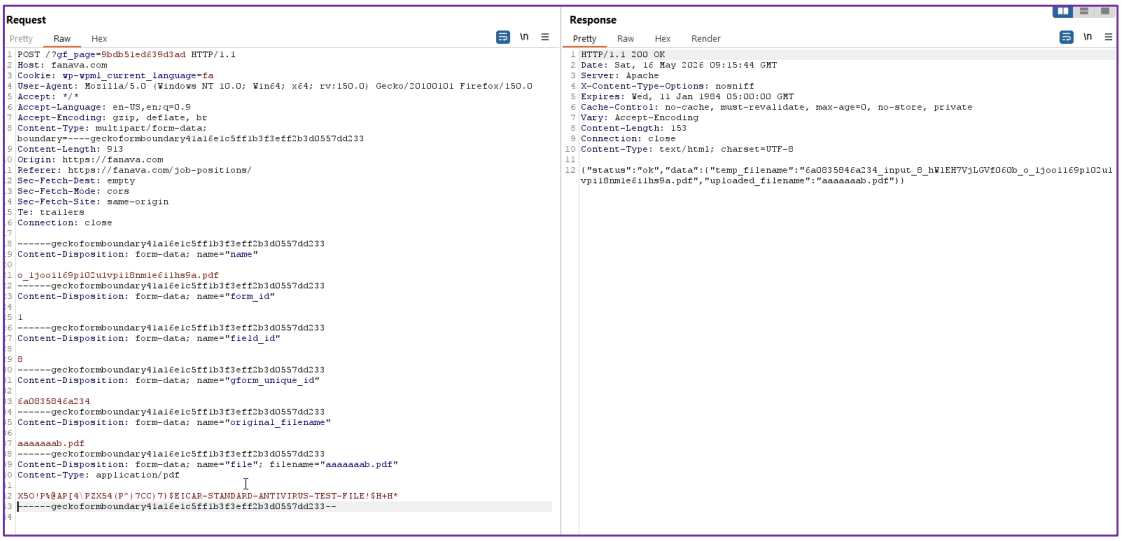
درخواست ارسال فایل سوابق آموزشی به شرح زیر است:

Request

Pre Raw Hex

```
1  POST /?gf_page=9bdb51ed639d3ad HTTP/1.1
2  Host: fanava.com
3  Cookie: wp-wpml_current_language=fa
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0) Gecko/20100101 Firefox/150.0
5  Accept: */*
6  Accept-Language: en-US,en;q=0.9
7  Accept-Encoding: gzip, deflate, br
8  Content-Type: multipart/form-data;
   boundary=----geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
9  Content-Length: 28415
10 Origin: https://fanava.com
11 Referer: https://fanava.com/job-positions/
12 Sec-Fetch-Dest: empty
13 Sec-Fetch-Mode: cors
14 Sec-Fetch-Site: same-origin
15 Te: trailers
16 Connection: close
17
18 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
19 Content-Disposition: form-data; name="name"
20
21 o_1joo1169p1021u1vpi18nm1e6i1hs9a.pdf
22 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
23 Content-Disposition: form-data; name="form_id"
24
25 1
26 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
27 Content-Disposition: form-data; name="field_id"
28
29 8
30 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
31 Content-Disposition: form-data; name="gform_unique_id"
32
33 6a0835846a234
34 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
35 Content-Disposition: form-data; name="original_filename"
36
37 aaaaaaab.pdf
38 ------geckoformboundary41a16e1c5ff1b3f3eff2b3d0557dd233
39 Content-Disposition: form-data; name="file"; filename="aaaaaaab.pdf"
40 Content-Type: application/pdf
41
42 %PDF-1.7
43 %□□□□
44 1 0 obj
45 <</Type/Catalog/Pages 2 0 R/Lang(en) /StructTreeRoot 15 0 R/MarkInfo<</Marked true>>/Metadata
   27 0 R/ViewerPreferences 28 0 R>>
46 endobj
47 2 0 obj
```

مهاجم در این درخواست محتوی فایل pdf را به یک فایل ویروس EICAR تغییر می‌دهد و درخواست را به سمت سامانه ارسال می‌کند. همان‌طور که در پاسخ این درخواست قابل مشاهده است فایل با محتوی مخرب با موفقیت در سامانه بارگذاری شده است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا موارد زیر بکار گرفته شود:

- تشخیص نوع فایل‌ها قبل از بارگذاری فایل
- اسکن فایل جهت جلوگیری از بارگذاری ویروس‌ها

محتوای فایل مطابق با فرمت فایل ارسالی باشد و از ارسال فایل‌هایی که محتوی آن با فرمت آن‌ها مطابقت ندارد جلوگیری شود.

حمله Reverse Denial of Service

این نوع حملات مانند حمله منع خدمت یا همان DOS هستند با این تفاوت که ترافیکی که سبب از کار انداختن سرور می‌شود از طریق داده‌هایی است که از سمت سرور برای کاربر ارسال می‌شوند به همین دلیل به آن Reverse DoS گفته می‌شود.

با توجه به بررسی‌های انجام شده بر روی سامانه، با ارسال درخواست مشاهده ویدیو صفحه اصلی به صورت متوالی سامانه برای مدتی از دسترس خارج می‌شود و هیچ مکانیزمی برای جلوگیری از حمله و یا بلاک کردن کاربر وجود ندارد.

شواهد اثبات آسیب پذیری

تصویر زیر درخواست مشاهده ویدیو در صفحه اصلی سامانه را نشان می‌دهد:

Request

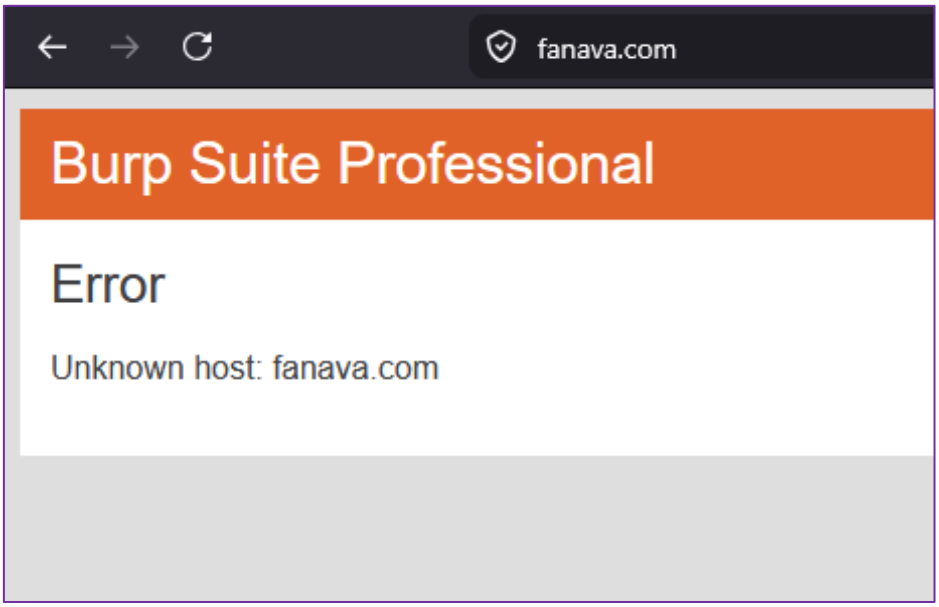
Pretty Raw H...

```
1  GET /wp-content/uploads/2025/07/Tiser-V3-web.mp4 HTTP/1.1
2  Host: fanava.com
3  Cookie: wp-wpml_current_language=fa;
   comment_author_email_9909f0ae31b286dc4052795b91e7a594=b@b.com
4  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:150.0)
   Gecko/20100101 Firefox/150.0
5  Accept:
   video/webm,video/ogg,video/*;q=0.9,application/ogg;q=0.7,audio/*;q=0.6,
   */*;q=0.5
6  Accept-Language: en-US,en;q=0.9
7  Range: bytes=3768320-
8  Referer: https://fanava.com/
9  Sec-Fetch-Dest: video
10 Sec-Fetch-Mode: no-cors
11 Sec-Fetch-Site: same-origin
12 Accept-Encoding: gzip, deflate, br
13 Priority: u=4
14 Te: trailers
15 Connection: close
16
17
```

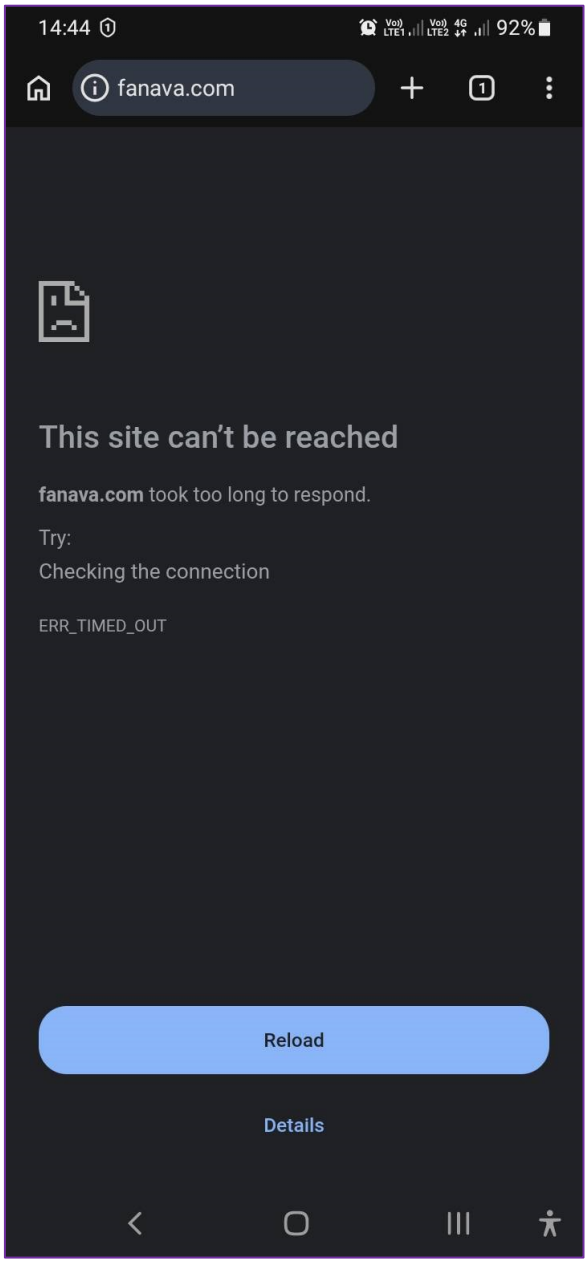
در تصویر زیر مهاجم چندین بار به صورت متوالی این درخواست را به سمت سامانه ارسال می‌کند. درخواست‌های ارسال شده از نوع NULL Payload بوده و همچنین هیچ خروجی به خود مهاجم نمایش نمی‌دهد و تنها حجم زیادی از درخواست برای مشاهده یک فایل سنگین در سامانه را ارسال می‌کند:



تصویر زیر از دسترس خارج شدن سامانه را نشان می‌دهد:



در تصویر زیر با استفاده از تلفن همراه و یک اینترنت غیر از اینترنت مهاجم در دسترس نبودن سامانه بررسی شده است:



راهکار پیشنهادی

جهت رفع این آسیب‌پذیری، پیشنهاد می‌شود تا اطلاعات صفحات سامانه به صورت محدود به سمت کاربر ارسال شوند و همچنین مکانیزم‌های امنیتی برای جلوگیری از ارسال درخواست‌های متوالی به سمت سامانه مانند WAF پیاده سازی شود.

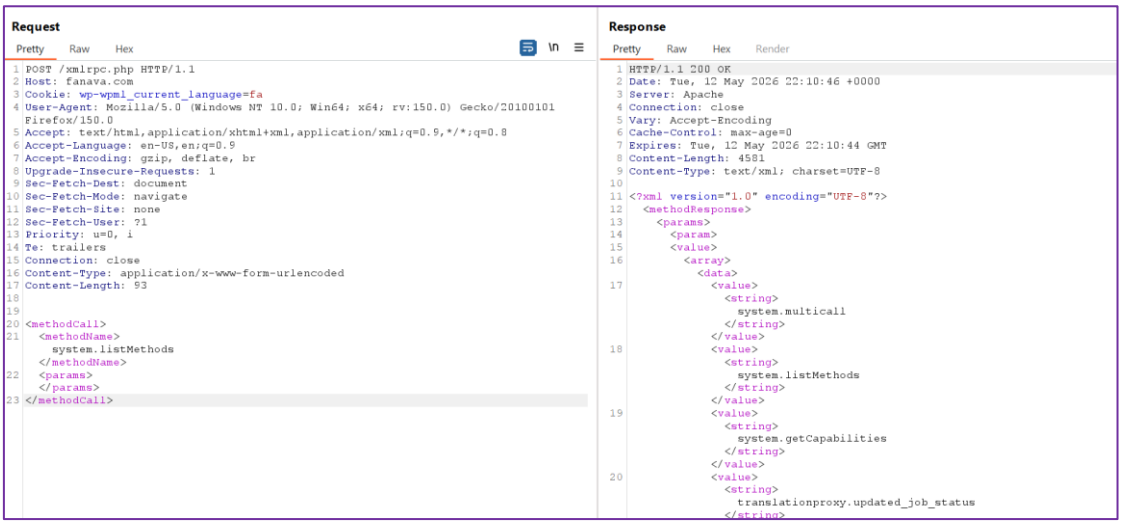
آسیب‌پذیری در دسترس بودن صفحه XML RPC

XML-RPC ویژگی است که ارتباط بین وردپرس و سایر سیستم ها را امکان پذیر می کند. XML-RPC از پروتکل HTTP به عنوان مکانیزم حمل و نقل و از XML به عنوان مکانیسم کدگذاری استفاده می نماید. از آنجا که وردپرس یک سیستم مستقل نیست و گاهی اوقات نیازمند برقراری ارتباط با دیگر سیستم ها است، XML-RPC ایجاد شده تا این مشکل را رفع کند.

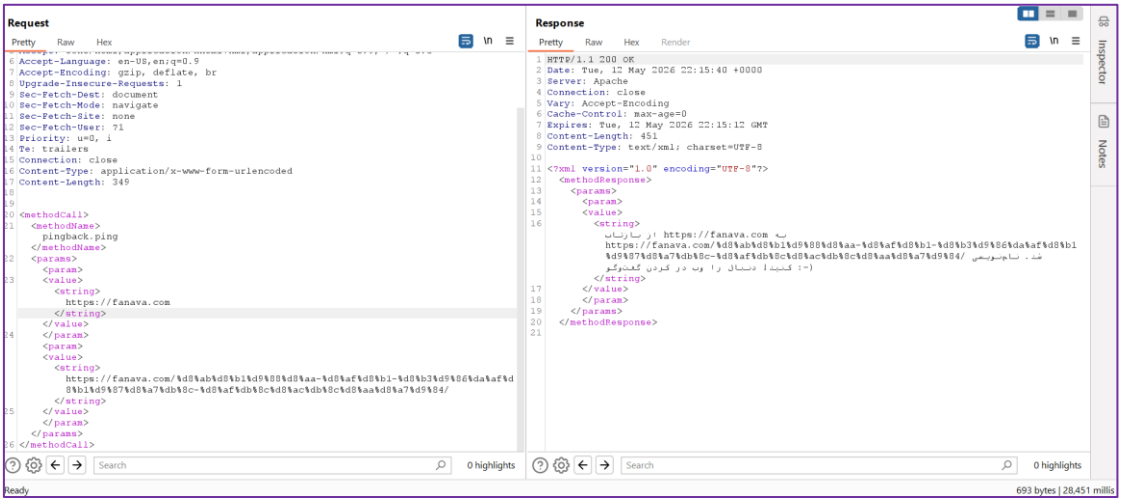
با توجه به بررسی‌های انجام شده بر روی سامانه، صفحه XML-RPC در دسترس کاربران سامانه می‌باشد که با کمک این فایل می توان حملات مختلفی را روی سایت های وردپرسی انجام داد.

شواهد اثبات آسیب پذیری

همان‌طور که در تصویر زیر قابل مشاهده است صفحه xml-rpc در دسترس کاربران می‌باشد و همچنین تمامی متدهای قابل استفاده در این صفحه نمایش داده شده است:



تصویر زیر صفحه xml-rpc و متد pingback ping را نمایش می‌دهد:



راهکار پیشنهادی

برای اینکه XML-RPC را غیرفعال کنید کدی را که در زیر قرار گرفته شده است را به فایل functions.php قالب وردپرس خود اضافه نمایید.

```
add_filter('xmlrpc_enabled', '__return_false');
```

فایل functions.php در مسیر wp-content/themes در هاست شما قابل دسترسی می باشد.

همچنین می‌تواند برای غیر فعال سازی XML-RPC از افزونه Disable XML-RPC استفاده کنید.

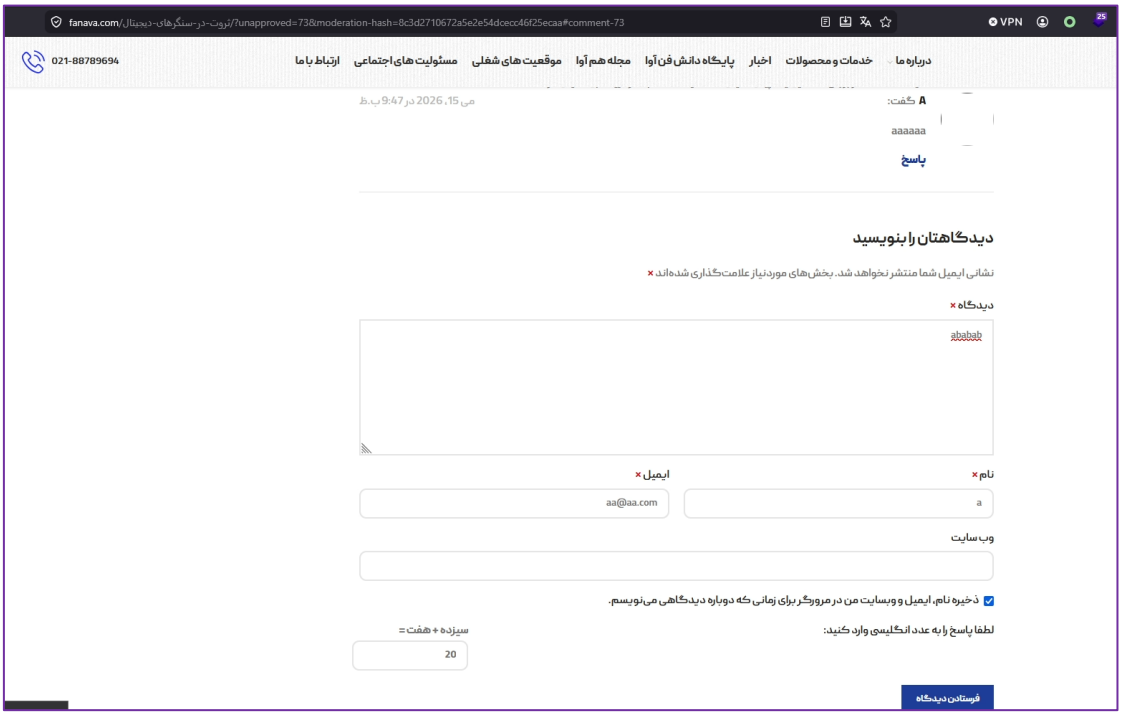
آسیب‌پذیری Session Fixation

زمانی که برنامه کاربردی شناسه نشست خود را پس از احرازهویت موفقیت‌آمیز کاربر به روز نمی‌کند، می‌تواند منجر به پیداش آسیب پذیری session fixation شود و کاربر را ملزم به استفاده از کوکی که برای مهاجم شناخته شده است، نماید. در این شرایط، مهاجم می‌تواند نشست کاربر را برباید و از طریق آن به پنل کاربر دسترسی داشته باشد و یا اطلاعات محرمانه او را مشاهده کند.

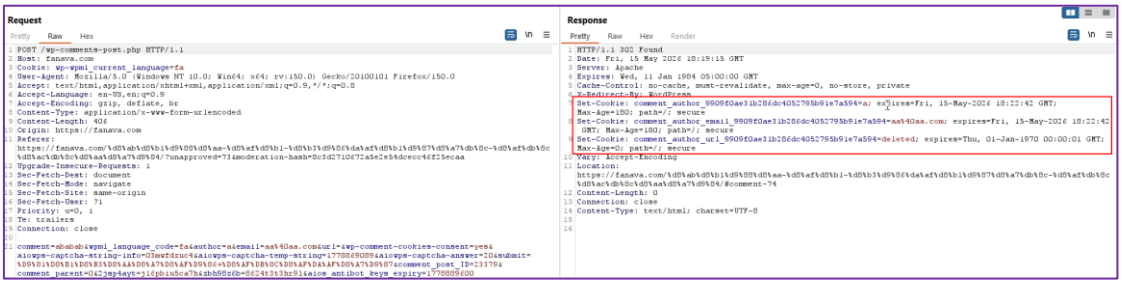
با توجه به بررسی‌های انجام شده در سامانه، در هنگام ثبت دیدگاه امکان ذخیره نام و ایمیل کاربر برای راحتی دسترسی و ثبت دیدگاه‌های دیگر کاربر وجود دارد. در این بخش مهاجم می‌تواند با در اختیار داشتن ایمیل سایر کاربران سامانه تنها با تغییر ایمیل خود به ایمیل کاربر دیگر در cookie، کامنت‌های ثبت شده سایر کاربران سامانه که هنوز تایید نشده‌اند را مشاهده کند.

شواهد اثبات آسیب پذیری

تصویر زیر صفحه ثبت دیدگاه را نمایش می‌دهد. در این صفحه کاربر بر روی گزینه ذخیره نام و ایمیل در مرورگر کلیک می‌کند و سپس درخواست خود را به سمت سامانه ارسال می‌کند:

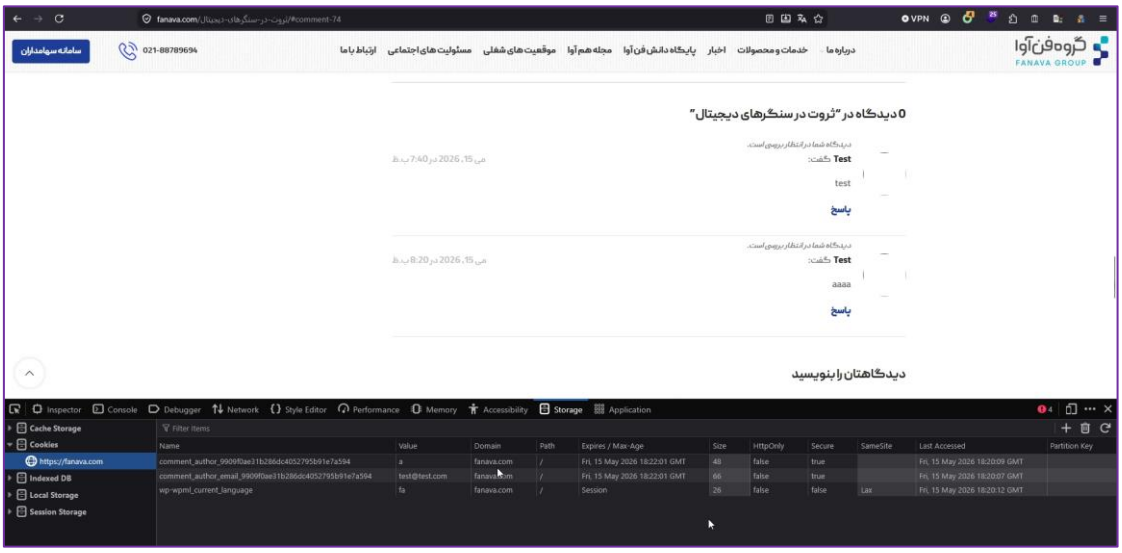


درخواست ارسال شده به سمت سامانه به شرح زیر است. همان‌طور که در پاسخ درخواست قابل مشاهده می‌باشد مقادیری به عنوان cookie کاربر تنظیم شده است:



کاربر در تصویر زیر مقدار ایمیل خود را به ایمیل یک کاربر دیگر تغییر می‌دهد و صفحه را refresh می‌کند.

همان‌طور که قابل مشاهده است دیدگاه‌های ثبت نشده کاربر جدید در صفحه نمایش داده می‌شود:



راهکار پیشنهادی

اقداماتی صورت پذیرد که امکان تغییر شناسه نشست برای کاربر به مقدار دلخواه امکان‌پذیر نباشد.

اقداماتی صورت پذیرد که شناسه نشست کاربر پس از احراز هویت باطل شده و شناسه نشست جدیدی برای کاربر ایجاد شود.

آسیب‌پذیری عدم مدیریت خطاهای پیش‌فرض

معمولا در طی فرایند بررسی نفوذپذیری سامانه، با کدهای خطایی مواجه می‌شویم که می‌تواند اطلاعات بسیار ارزشمندی درباره نوع و نسخه تکنولوژی‌های استفاده شده در سامانه را در اختیار نفوذگر قرار دهد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه فرایند مدیریت خطا در بخش جستجوی مقاله به درستی پیاده سازی نشده است و با تغییر پارامتر جستجو از s=test به s[]= امکان مشاهده خطا و افشای مسیرهای داخلی سامانه وجود دارد. همچنین در بخش‌های دیگر سامانه که امکان تغییر پارامتر به صورت ذکر شده وجود داشته باشد، سامانه دچار خطا می‌شود:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری پیشنهاد می‌شود برای نمایش خطاها از صفحات شخصی سازی شده استفاده شود تا از افشای اطلاعات درباره نوع و نسخه وب سرور سامانه جلوگیری کند.

آسیب‌پذیری HTTP Splitting Smuggling

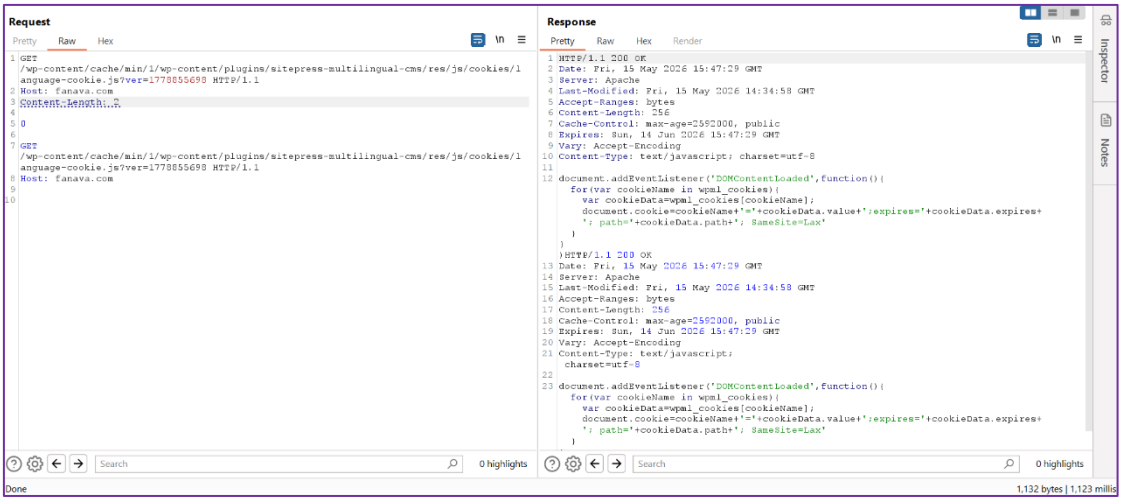
HTTP Request Smuggling یک نوع آسیب‌پذیری در پروتکل HTTP است که به مهاجم امکان می‌دهد درخواست‌های HTTP را به گونه‌ای دستکاری کند که سرور اصلی و سرور پراکسی (یا لود بالانسر) به اشتباه درخواست‌های متفاوتی را پردازش کنند. این آسیب‌پذیری زمانی رخ می‌دهد که یک سیستم از چندین سرور و پروکسی برای پردازش درخواست‌های HTTP استفاده می‌کند و بین سرورها، هم‌ترازی در تفسیر درخواست‌ها وجود ندارد.

اگر سرور پراکسی و سرور اصلی به صورت متفاوتی ساختار درخواست را تفسیر کنند، مهاجم می‌تواند با دستکاری خاصی، دو درخواست مجزا را طوری ترکیب کند که یکی از آن‌ها برای سرور اصلی و دیگری برای سرور پراکسی پردازش شود. این عدم هم‌ترازی می‌تواند به مهاجم اجازه دهد تا:

- **از محدودیت‌های امنیتی عبور کند:** مهاجم می‌تواند دسترسی به منابعی داشته باشد که معمولاً محدود شده‌اند.
- **اجرای درخواست‌های غیرمجاز:** می‌تواند درخواست‌های مخربی ارسال کند که سرور آن‌ها را به عنوان درخواست‌های معتبر پردازش می‌کند.
- **اجرای حملات دیگر:** مانند تزریق اسکریپت، سرقت اطلاعات یا دور زدن محدودیت‌های احراز هویت.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده در سامانه، این آسیب‌پذیری وجود دارد. همان‌طور که در تصویر زیر قابل مشاهده می‌باشد مهاجم با ارسال ۲ درخواست به صورت همزمان به سمت سرور پاسخ در دو درخواست را دریافت می‌کند.



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری، پیشنهاد می‌گردد تا موارد زیر مورد توجه قرار گیرد:

- **استفاده از سرورهای همسان:** اطمینان حاصل کنید که تمام سرورها و پروکسی‌های درگیر در زنجیره درخواست، نسخه‌ها و تنظیمات مشابهی دارند تا از تفسیرهای متفاوت جلوگیری شود.
- **فیلتر کردن ورودی‌ها:** ورودی‌هایی که توسط کاربر ارائه می‌شوند باید به دقت فیلتر شوند تا از تزریق رشته‌های نامتعارف جلوگیری شود.
- **تایید و تصدیق طول محتوا:** در درخواست‌های HTTP از هدرهای Content-Length و Transfer-Encoding استفاده می‌شود. اطمینان حاصل کنید که این هدرها با هم سازگار هستند و طول محتوا درست تفسیر می‌شود.
- **بروزرسانی سرورها و پروکسی‌ها:** بسیاری از آسیب‌پذیری‌های HTTP Smuggling به دلیل وجود باگ در سرورها یا پروکسی‌ها است. بروزرسانی مداوم نرم‌افزارها و اعمال پچ‌های امنیتی ضروری است.
- **استفاده از فایروال وب (WAF):** برخی از فایروال‌های وب به صورت خاص برای شناسایی و مقابله با حملات HTTP Smuggling طراحی شده‌اند. تنظیمات آن‌ها را به گونه‌ای انجام دهید که این نوع از حملات شناسایی و مسدود شوند.

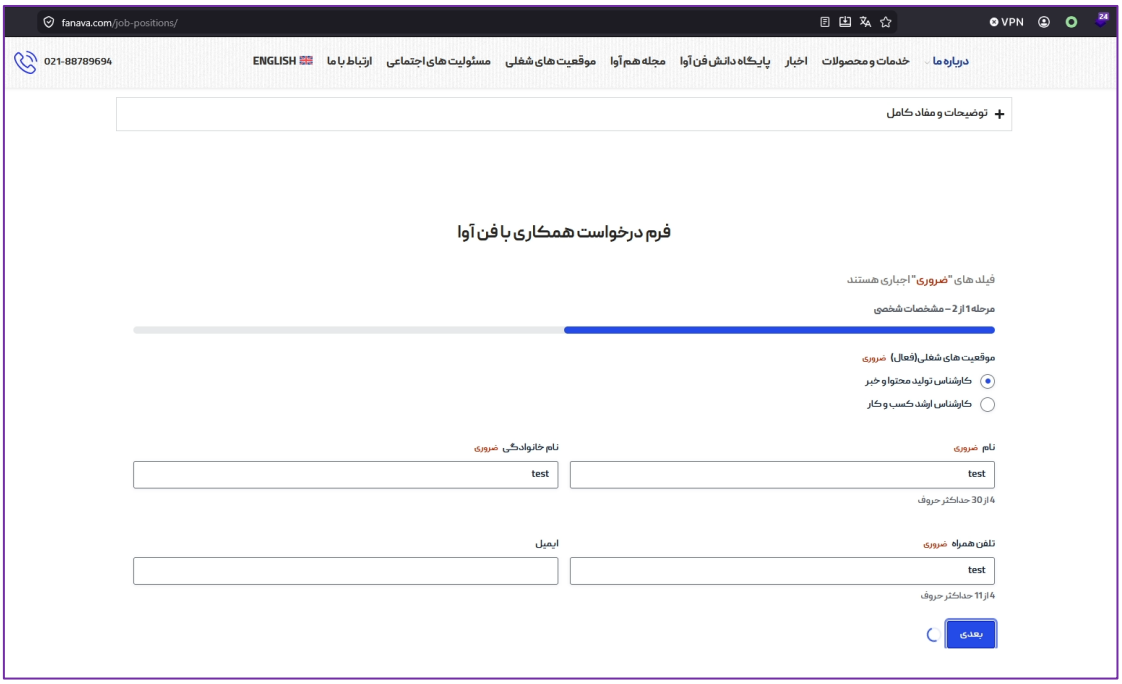
آسیب‌پذیری CVE-2026-4406 - Reflected XSS

در صورتی که سامانه در فیلدهای ورودی اطلاعات خود، مانند بخش جستجوی سامانه، اعتبارسنجی مناسبی بر روی داده‌های ورودی انجام ندهد، امکان بروز این آسیب‌پذیری برای کاربر وجود دارد. اگر یک سامانه دارای این آسیب‌پذیری باشد و مهاجم بتواند پیلود مخرب خود را در ورودی‌ها وارد کند، کاربر به محض متصل شدن به صفحه آسیب‌پذیر، کد مخرب مورد نظر مهاجم را از طریق مرورگر خود اجرا می‌کند و اطلاعات حساس قربانی از این طریق برای مهاجم ارسال می‌شود.

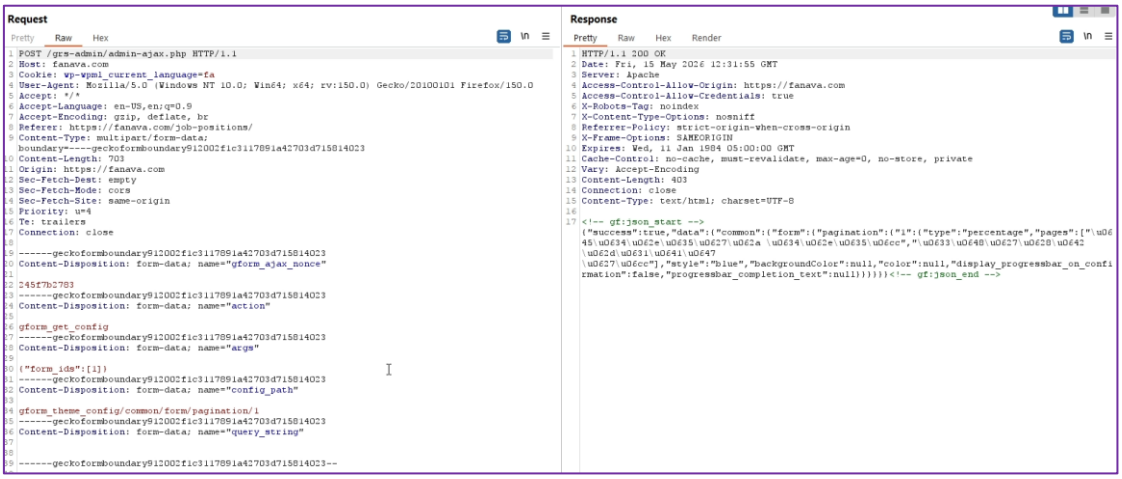
با توجه به بررسی‌های انجام شده در بخش موقعیت‌های شغلی سامانه در صفحه -/wp-admin/admin ajax.php، در پارامتر form_id و بخش gform_get_config امکان تزریق کد HTLM وجود دارد که منجر به بروز آسیب‌پذیری Reflected XSS در Gravity Forms با شماره CVE-2026-4406 می‌شود.

شواهد اثبات آسیب پذیری

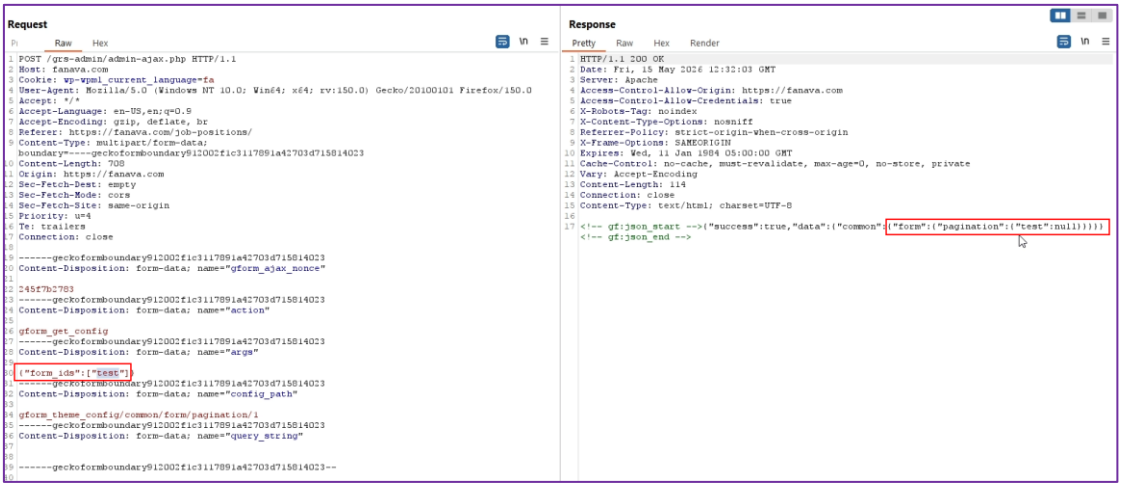
تصویر زیر بخش موقعیت‌های شغلی سامانه را نشان می‌دهد. در این بخش کاربر اطلاعات اولیه خود را وارد می‌کند و بر روی گزینه "بعدی" کلیک می‌کند:



پس از کلیک بر روی این گزینه درخواست زیر به سمت سامانه ارسال می‌شود. این درخواست مربوط به Gravity Forms می‌باشد و اطلاعات مربوط به فایل کانفیگ را در پاسخ نمایش می‌دهد:

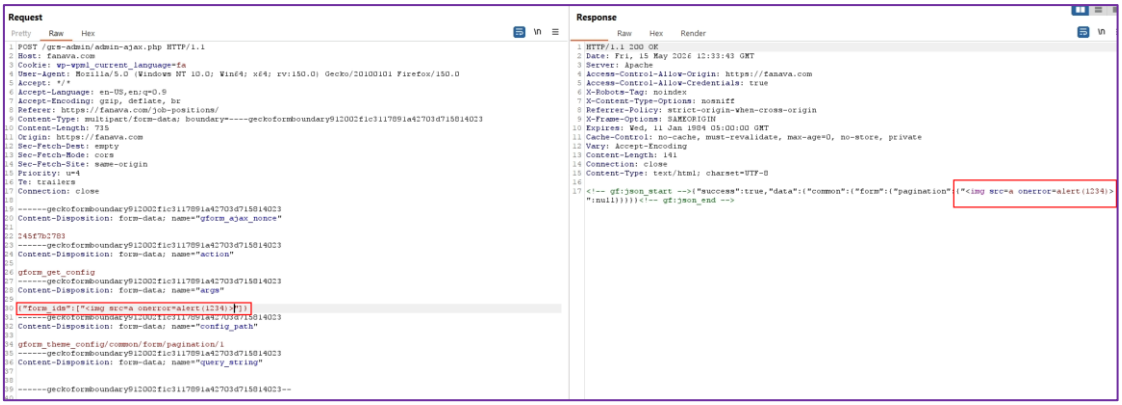


مهاجم در این درخواست، مقدار ۱ در مقابل form_id را با مقدار "test" جایگزین می‌کند. همان‌طور که در پاسخ این درخواست قابل مشاهده می‌باشد مقدار test در بخش form - pagination بازگشت داده شده است:

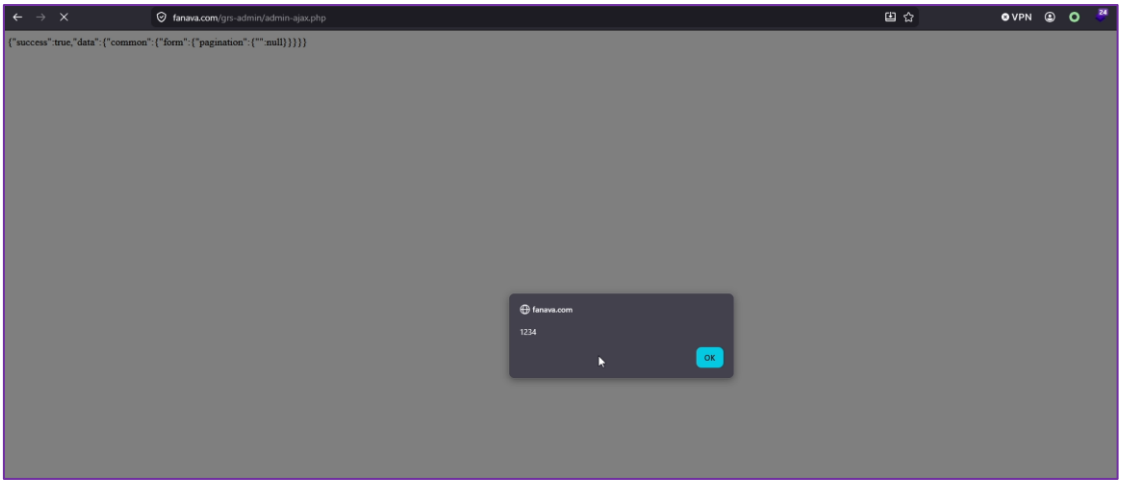


مهاجم در بخش form پیلود مخرب HTML خود را قرار می‌دهد. همان‌طور که در پاسخ این درخواست قابل مشاهده می‌باشد این پیلود بدون هیچگونه sanitization بازگشت داده شده است. مقدار پیلود به شرح زیر است:

<img src=a onerror=alert(1234)>



تصویر زیر پاسخ درخواست فوق و اجرا شدن پیلود مخرب در مرورگر کاربر را نمایش می‌دهد:



راهکار پیشنهادی

برای امن سازی سامانه در مقابل این آسیب‌پذیری موارد زیر پیشنهاد می‌شود:

در مرحله اول پیشنهاد می‌شود از آخرین نسخه gravity forms و wordpress استفاده شود.

مقادیر ورودی در پارامتر form_ids بررسی شود تا در صورتی که مقادیر با ^[0-9]+$ همخوانی نداشت، قبل از process شدن reject شود.

```
$form_ids = array_map('intval', $form_ids);
$form_ids = array_filter($form_ids, function($id) { return $id > 0; });
```

خروجی به صورت encode شده نمایش داده شود. flag های JSON_HEX_TAG | JSON_HEX_AMP | JSON_HEX_APOS | JSON_HEX_QUOT در wp_json_encode() مطابق تنظیمات زیر اعمال شود:

```
echo wp_json_encode($response_data, JSON_HEX_TAG | JSON_HEX_AMP | JSON_HEX_APOS | JSON_HEX_QUOT);
```

برای تمامی درخواست‌های AJAX سرایند Content-Type با مقدار application/json تنظیم شود.

```
header('Content-Type: application/json; charset=UTF-8');
```

از سرایند csp یا Content Security Policy در سرور استفاده شود.

آسیب‌پذیری Directory Listing

بسیاری از برنامه‌های کاربردی وب فایل‌ها را به عنوان بخشی از عملیات روزانه‌ی خود مدیریت و استفاده می‌کنند. همچنین با توجه به اهمیت حفظ این فایل‌ها، مکانیسم‌های احرازهویت برای کنترل دسترسی به فایل‌ها و منابع را پیاده‌سازی و privilegeهایی را با استفاده از لیست‌های کنترل دسترسی که مشخص می‌کند کدام یک از کاربران یا گروه‌های کاربری قادر به دسترسی، تغییر یا اجرای یک فایل بخصوصی در سرور هستند، تعریف می‌کنند.

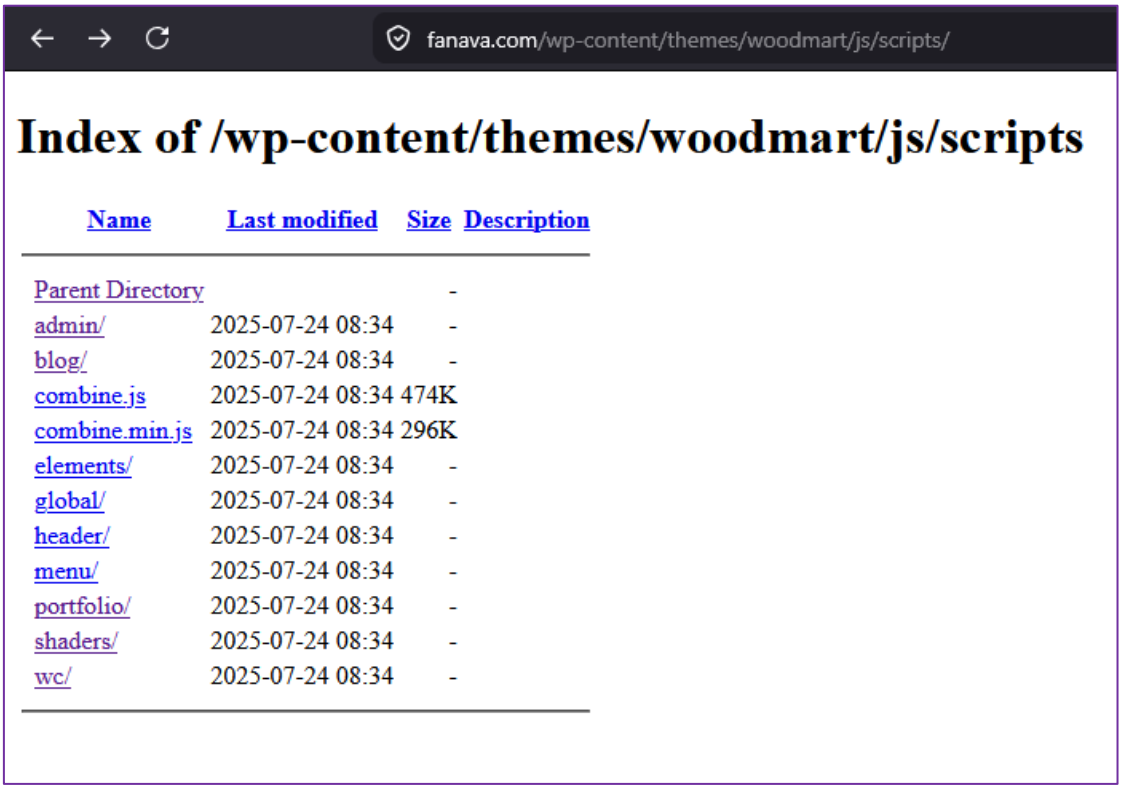
در صورتی که در این برنامه‌ها استفاده از روش‌های اعتبارسنجی ورودی‌ها به خوبی طراحی و پیاده‌سازی نشده باشد، شرایط را برای بهره‌برداری مهاجم فراهم می‌کند و منجر به افشای اطلاعات حساسی می‌شود. مانند:

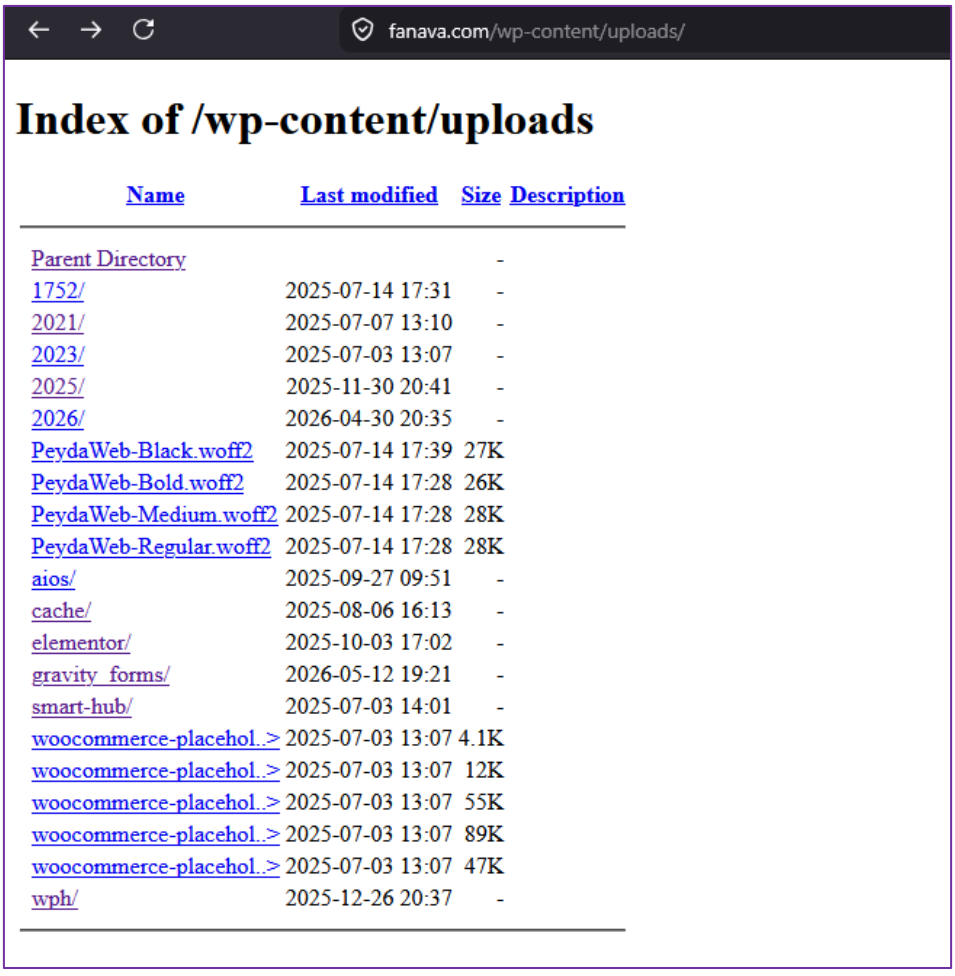
- فایل‌های پشتیبان (backup.zip)
- فایل‌های تنظیمات
- سورس‌کد
- کلیدها و credential ها
- ساختار داخلی برنامه

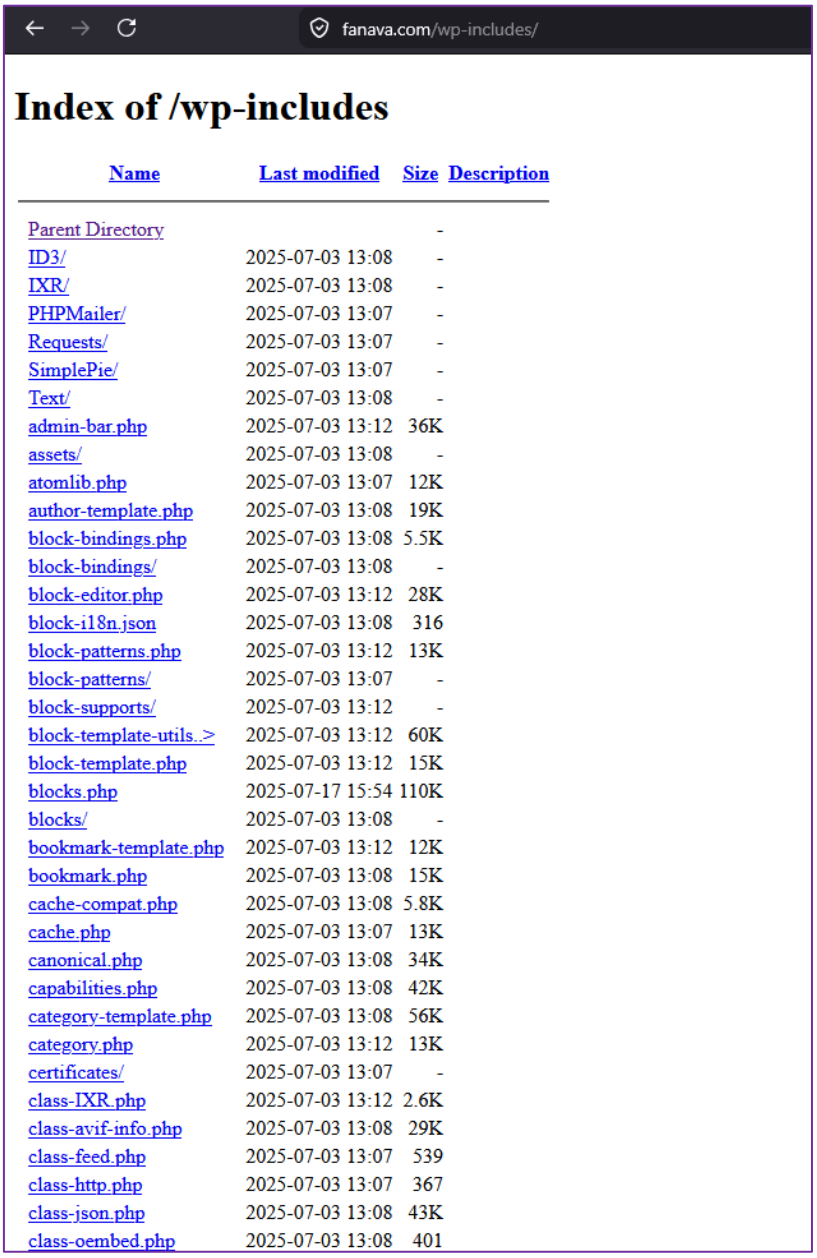
و در بعضی موارد مسیر را برای حملات بعدی باز می‌کند.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده در سامانه، آسیب‌پذیری Directory Listing در مسیرهای فایل‌های wordpress وجود دارد.تصاویر زیر برخی از این فایل‌ها و مسیرها را نمایش می‌دهد:


fanava.com/wp-content/themes/woodmart/js/scripts/
Index of /wp-content/themes/woodmart/js/scripts
Name Last modified Size Description
Parent Directory -
admin/ 2025-07-24 08:34 -
blog/ 2025-07-24 08:34 -
combine.js 2025-07-24 08:34 474K
combine.min.js 2025-07-24 08:34 296K
elements/ 2025-07-24 08:34 -
global/ 2025-07-24 08:34 -
header/ 2025-07-24 08:34 -
menu/ 2025-07-24 08:34 -
portfolio/ 2025-07-24 08:34 -
shaders/ 2025-07-24 08:34 -
wc/ 2025-07-24 08:34 -


fanava.com/wp-content/uploads/
Index of /wp-content/uploads
Name Last modified Size Description
Parent Directory -
1752/ 2025-07-14 17:31 -
2021/ 2025-07-07 13:10 -
2023/ 2025-07-03 13:07 -
2025/ 2025-11-30 20:41 -
2026/ 2026-04-30 20:35 -
PeydaWeb-Black.woff2 2025-07-14 17:39 27K
PeydaWeb-Bold.woff2 2025-07-14 17:28 26K
PeydaWeb-Medium.woff2 2025-07-14 17:28 28K
PeydaWeb-Regular.woff2 2025-07-14 17:28 28K
aios/ 2025-09-27 09:51 -
cache/ 2025-08-06 16:13 -
elementor/ 2025-10-03 17:02 -
gravity_forms/ 2026-05-12 19:21 -
smart-hub/ 2025-07-03 14:01 -
woocommerce-placehol..> 2025-07-03 13:07 4.1K
woocommerce-placehol..> 2025-07-03 13:07 12K
woocommerce-placehol..> 2025-07-03 13:07 55K
woocommerce-placehol..> 2025-07-03 13:07 89K
woocommerce-placehol..> 2025-07-03 13:07 47K
wph/ 2025-12-26 20:37 -



راهکار پیشنهادی

به منظور این رفع آسیب‌پذیری پیشنهاد می گردد تا موارد زیر بکار گرفته شود:

غیرفعال کردن Directory Listing در وب‌سرور Apache

داخل .htaccess یا کانفیگ Apache:

```
Options -Indexes
```

غیرفعال کردن Directory Listing در وب‌سرور Nginx

در فای پیکربندی Nginx:

```
autoindex off;
```

محدود کردن دسترسی برای پوشه‌های حساس.

تنظیم احراز هویت، تنظیم Permission مناسب و جلوگیری از دسترسی Public به فایل‌های حساس سامانه انجام شود.

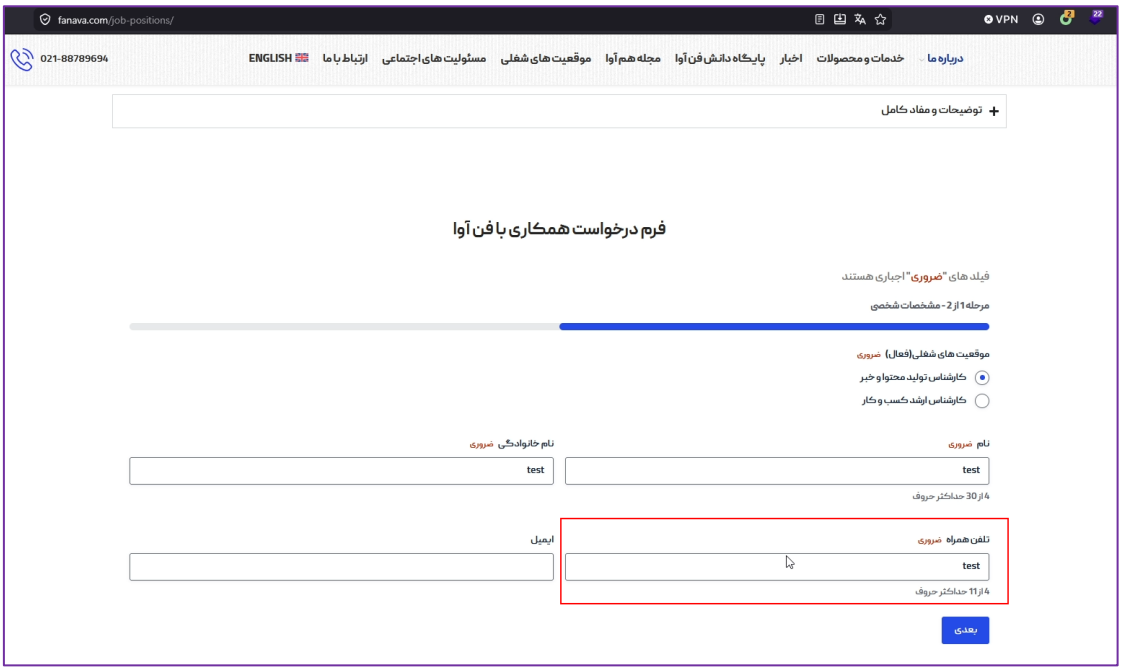
آسیب‌پذیری اعتبارسنجی ورودی‌ها

آسیب پذیری اعتبار سنجی ورودی یا input validation، فرایندی است که در آن، ورودی‌های یک برنامه یا سیستم به دقت بررسی می‌شوند تا اطمینان حاصل شود که این ورودی‌ها مطابق با انتظارات و محدودیت‌های تعریف شده هستند و از بروز آسیب پذیری‌های امنیتی مانند sql injection و یا افشای اطلاعات کاربر جلوگیری می‌کنند.

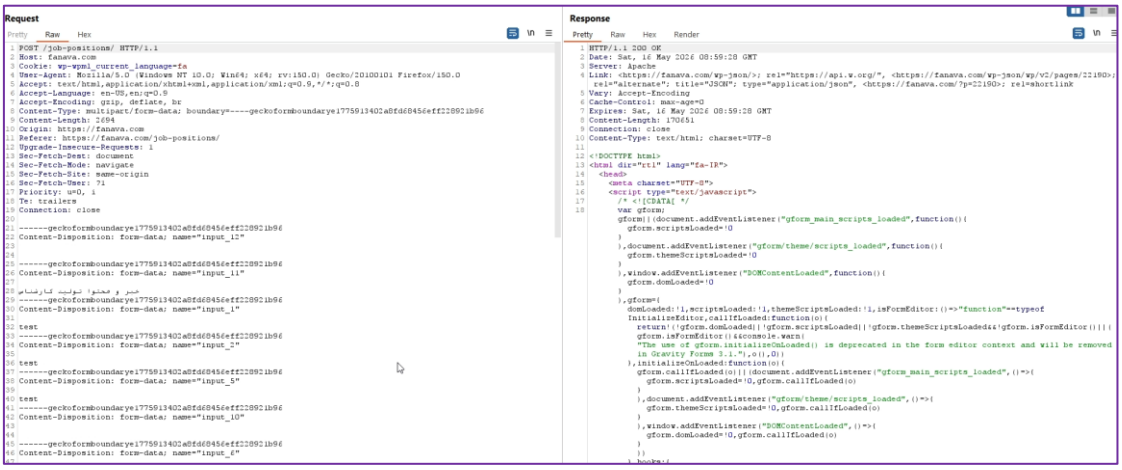
شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سامانه، در بخش ثبت فرم درخواست همکاری در بخش تلفن همراه امکان وارد کردن هر مقداری غیر از مقادیر عددی وجود دارد.

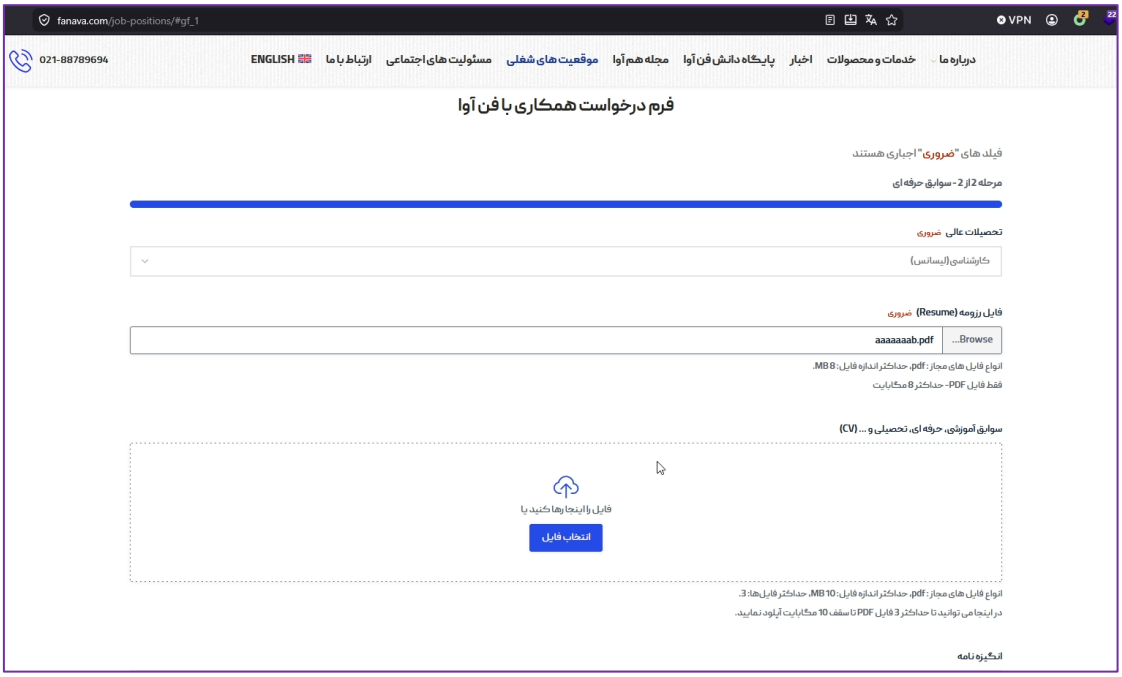
تصویر زیر بخش فرم درخواست همکاری را نمایش می‌دهد. همان‌طور که در این بخش قابل مشاهده می‌باشد کاربر در بخش تلفن همراه مقدار test را قرار داده است:



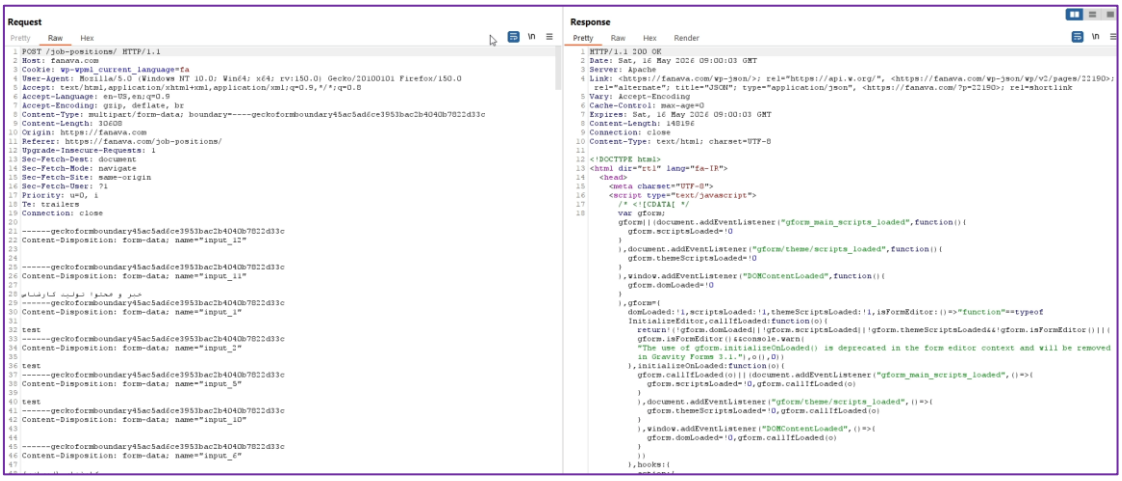
درخواست تصویر فوق به شرح زیر است:



در تصویر زیر کاربر فایل رزومه خود را وارد می‌کند و در انتها فرم درخواست همکاری را ارسال می‌کند:



درخواست نهایی ارسال فرم در تصویر زیر نمایش داده شده است. همان‌طور که قابل مشاهده است این درخواست (با مقدار test به جای شماره تماس) با موفقیت به سمت سامانه ارسال شده است و پاسخ با کد ۲۰۰ بازگشت داده شده است:



تصویر زیر ثبت شدن فرم درخواست همکاری را نشان می‌دهد:



راهکار پیشنهادی

به منظور رفع این آسیب‌پذیری موارد زیر توصیه می‌شود:

- **Validations:** بررسی‌هایی که بر روی ورودی‌ها انجام می‌شوند تا اطمینان حاصل شود که ورودی‌ها مطابق با فرمت، طول و نوع داده‌ای تعریف شده هستند.
- **Sanitization:** پالایش ورودی‌ها از هرگونه کاراکتر یا کد مخرب قبل از اینکه به داخل برنامه یا پایگاه داده وارد شوند.
- **Escaping:** تغییر کاراکترهای خاص در ورودی‌ها به گونه‌ای که آنها به عنوان کد شناسایی نشوند و از حملات تزریق کد جلوگیری شود.

- **Blacklisting**: فیلتر کردن و مسدود کردن ورودی‌های خاص که شناخته شده‌اند و می‌توانند خطرناک باشند.
- **Whitelisting**: مجوز دادن تنها به ورودی‌هایی که در لیست سفید قرار دارند و شناخته شده و امن هستند.

آسیب‌پذیری Click-Jacking

این نوع حمله، کاربر را فریب می‌دهد تا بر روی عناصر مختلف صفحه وب که یا نامرئی هستند و یا تبدیل به یک عنصر دیگر می‌شوند، کلیک کند. این امر می‌تواند منجر به دانلود ناخواسته بدافزار، بازدید از وب‌سایت‌های مخرب، ارائه‌ی اطلاعات مهم، انتقال مبلغ یا خرید آنلاین گردد. این آسیب‌پذیری به دلیل عدم تنظیم سرایند X-Frame-Options در درخواست‌های سامانه می‌باشد.

شواهد اثبات آسیب پذیری

همان‌طور که در تصویر زیر قابل مشاهده است مهاجم یک صفحه HTML جعلی ساخته و اقدام به باز کردن سامانه با تگ Iframe کرده است:

```html
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta http-equiv="X-UA-Compatible" content="IE=edge">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>ClickJacking Test Page</title>
</head>
<body>
    <h1>ClickJacking Test Page</h1>
    <iframe src="https://fanava.com" width="700" height="700"></iframe>

</body>
</html>
```

تصویر زیر باز شدن صفحه سامانه توسط فایل HTML مهاجم را نشان می‌دهد:



راهکار پیشنهادی

به منظور پیشگیری از حملات Clickjacking می‌توان از روش‌های زیر استفاده کرد.

استفاده از هدرهای HTTP امنیتی یکی از موثرترین و پرکاربردترین روش‌ها برای جلوگیری از Clickjacking است که شامل موارد زیر می‌باشد:

X-Frame-Options: این هدر مشخص می‌کند که آیا مرورگر اجازه دارد محتوای صفحه را درون iFrame نمایش دهد یا خیر. سه گزینه معمول برای این هدر وجود دارد:

- **DENY:** اجازه نمی‌دهد که صفحه درون iFrame قرار گیرد.
- **SAMEORIGIN:** تنها در صورتی اجازه می‌دهد صفحه درون iFrame نمایش داده شود که از همان دامنه باشد.
- **ALLOW-FROM URI:** تنها اجازه نمایش درون iFrame با دامنه یا URL مشخص شده را می‌دهد (البته این گزینه کمتر استفاده می‌شود، زیرا برخی مرورگرها آن را پشتیبانی نمی‌کنند).

Content Security Policy (CSP): این هدر پیشرفته‌تر از X-Frame-Options است و با تنظیم آن می‌توانید مشخص کنید که منابع صفحه از کدام دامنه‌ها بارگذاری شوند. برای جلوگیری از Clickjacking، می‌توانید از دستور frame-ancestors استفاده کنید:

```
Content-Security-Policy: frame-ancestors 'self';
```

عدم وجود سرآیندهای امنیتی HTTP

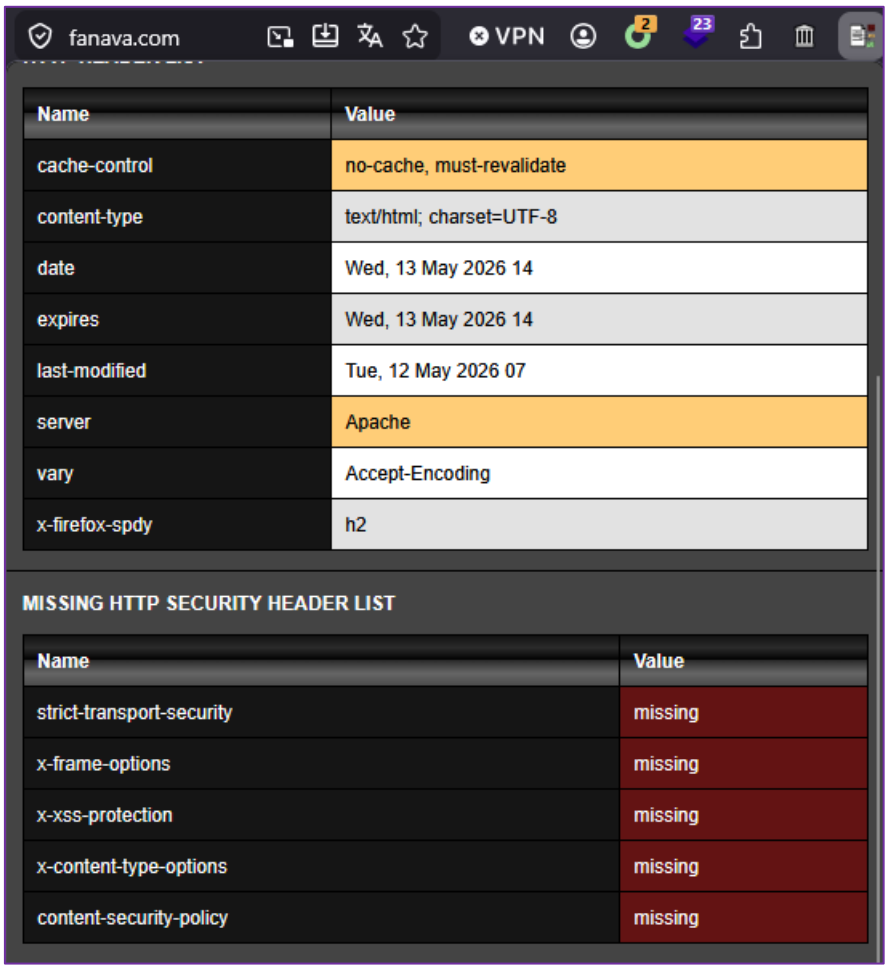
سرآیندهای امنیتی، مجموعه سرآیندی‌هایی هستند که در پاسخ وب‌سرور به سمت مرورگر کاربر ارسال می‌گردند که اغلب باعث افزایش امنیت کاربر در تعامل با سامانه می‌شوند و در صورت غیرفعال بودن هر یک از سرآیندها امکان به وقوع پیوستن حملاتی چون Clickjacking، XSS و... را به همراه دارد.

شواهد اثبات آسیب پذیری

با توجه به بررسی‌های انجام شده بر روی سرایندهای ارسالی در درخواست‌های سامانه، سرایندهای زیر در سامانه وجود ندارند:

Strict-Transport-Security,x-frame-options, x-xss-protection X-Content-Type-Options, Content-Security-Policy

تصویر زیر بررسی سرایندهای سامانه را نشان می‌دهد:



راهکار پیشنهادی

در فایل پیکربندی سامانه سرآیندهای ذکر شده را تنظیم کنید.